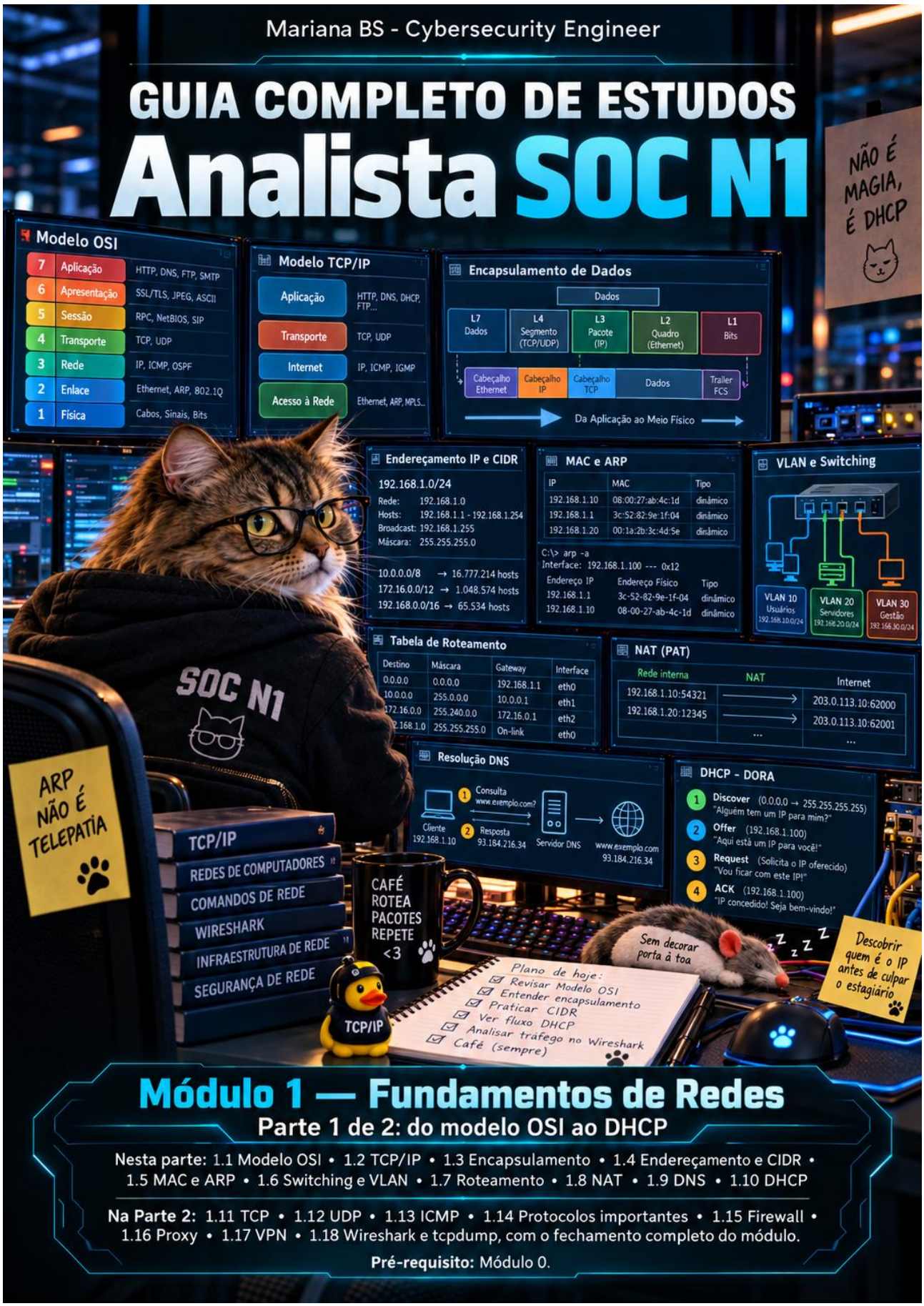

Mariana BS - Cybersecurity Engineer
GUIA COMPLETO DE ESTUDOS
Analista SOC N1
NÃO É MAGIA, É DHCP
Modelo OSI
7 Aplicação HTTP, DNS, FTP, SMTP
6 Apresentação SSL/TLS, JPEG, ASCII
5 Sessão RPC, NetBIOS, SIP
4 Transporte TCP, UDP
3 Rede IP, ICMP, OSPF
2 Enlace Ethernet, ARP, 802.1Q
1 Física Cabos, Sinais, Bits
Modelo TCP/IP
Aplicação HTTP, DNS, DHCP, FTP...
Transporte TCP, UDP
Internet IP, ICMP, IGMP
Acesso à Rede Ethernet, ARP, MPLS...
Encapsulamento de Dados
Dados
L7 Dados
L4 Segmento (TCP/UDP)
L3 Pacote (IP)
L2 Quadro (Ethernet)
L1 Bits
Cabeçalho Ethernet
Cabeçalho IP
Cabeçalho TCP
Dados
Trailer FCS
Da Aplicação ao Meio Físico
Endereçamento IP e CIDR
192.168.1.0/24
Rede: 192.168.1.0
Hosts: 192.168.1.1 - 192.168.1.254
Broadcast: 192.168.1.255
Máscara: 255.255.255.0
10.0.0.0/8 → 16.777.214 hosts
172.16.0.0/12 → 1.048.574 hosts
192.168.0.0/16 → 65.534 hosts
MAC e ARP
IP MAC Tipo
192.168.1.10 08:00:27:ab:4c:1d dinâmico
192.168.1.1 3c:52:82:9e:1f:04 dinâmico
192.168.1.20 00:1a:2b:3c:4d:5e dinâmico
C:\> arp -a
Interface: 192.168.1.100 --- 0x12
Endereço IP Endereço Físico Tipo
192.168.1.1 3c-52-82-9e-1f-04 dinâmico
192.168.1.10 08-00-27-ab-4c-1d dinâmico
VLAN e Switching
VLAN 10 Usuários
VLAN 20 Servidores
VLAN 30 Gestão
Tabela de Roteamento
Destino Máscara Gateway Interface
0.0.0.0 0.0.0.0 192.168.1.1 eth0
10.0.0.0 255.0.0.0 10.0.0.1 eth1
172.16.0.0 255.240.0.0 172.16.0.1 eth2
192.168.1.0 255.255.255.0 On-link eth0
NAT (PAT)
Rede interna NAT Internet
192.168.1.10:54321 → 203.0.113.10:62000
192.168.1.20:12345 → 203.0.113.10:62001
Resolução DNS
Cliente 192.168.1.10
1 Consulta www.exemplo.com?
2 Resposta 93.184.216.34
Servidor DNS
www.exemplo.com 93.184.216.34
DHCP - DORA
1 Discover (0.0.0.0 → 255.255.255.255) "Alguém tem um IP para mim?"
2 Offer (192.168.1.100) "Aqui está um IP para você!"
3 Request (Solicita o IP oferecido) "Vou ficar com este IP!"
4 ACK (192.168.1.100) "IP concedido! Seja bem-vindo!"
ARP NÃO É TELEPATIA
TCP/IP
REDES DE COMPUTADORES
COMANDOS DE REDE
WIRESHARK
INFRAESTRUTURA DE REDE
SEGURANÇA DE REDE
CAFÉ ROTEA PACOTES REPETE <3
TCP/IP
Sem decorar porta à toa
Plano de hoje:
Revisar Modelo OSI
Entender encapsulamento
Praticar CIDR
Ver fluxo DHCP
Analisar tráfego no Wireshark
Café (sempre)
Descobrir quem é o IP antes de culpar o estagiário
Módulo 1 — Fundamentos de Redes
Parte 1 de 2: do modelo OSI ao DHCP
Nesta parte: 1.1 Modelo OSI • 1.2 TCP/IP • 1.3 Encapsulamento • 1.4 Endereçamento e CIDR • 1.5 MAC e ARP • 1.6 Switching e VLAN • 1.7 Roteamento • 1.8 NAT • 1.9 DNS • 1.10 DHCP
Na Parte 2: 1.11 TCP • 1.12 UDP • 1.13 ICMP • 1.14 Protocolos importantes • 1.15 Firewall • 1.16 Proxy • 1.17 VPN • 1.18 Wireshark e tcpdump, com o fechamento completo do módulo.
Pré-requisito: Módulo 0.

Sumário

Módulo 1 — Fundamentos de Redes (Parte 1) 4
Objetivo do módulo 4
1.1 Modelo OSI 4
O que é e por que existe 4
Unidades de dados (PDU) 5
As camadas em detalhe 6
Tabela de referência rápida 9
Por que o OSI é útil se não é perfeito 9
1.2 Modelo TCP/IP 10
OSI x TCP/IP: diferenças que importam 11
1.3 Encapsulamento e o caminho completo de uma requisição 11
O que é encapsulamento 11
Passo a passo: o que acontece quando o usuário abre https://empresa.com 12
Quem enxerga o quê nesse fluxo 14
1.4 Endereçamento IP 14
IPv4 14
IPv6 (o básico para não travar) 15
Tipos de endereço que o N1 precisa reconhecer à primeira vista 15
Unicast, broadcast e multicast 16
CIDR, máscara e sub-redes 16
O truque do "tamanho do bloco" 17
As três perguntas que o N1 precisa responder 17
Comandos 18
1.5 MAC e ARP 19
Endereço MAC 19
ARP — Address Resolution Protocol 19
ARP spoofing (envenenamento de ARP) 20
Logs relacionados 20
Comandos 21
1.6 Switching e VLAN 21
Switch e tabela MAC 21
VLAN, portas access e trunk, 802.1Q 21
Segmentação e por que VLAN importa em investigação 22
Ataques de camada 2 relacionados (visão defensiva) 23
Logs relacionados 23
1.7 Roteamento 24
Comandos 25
Como isso aparece no SOC 25

1.8 NAT 25
O que é e por que existe 26
Por que NAT dificulta a investigação 26
Cadeia de atribuição: do IP público até a pessoa 27
1.9 DNS 28
O que é e por que é tão importante para o SOC 28
Tipos de registro 28
Como a resolução funciona 28
Abusos de DNS (visão defensiva) 29
Logs relacionados 30
Comandos 30
1.10 DHCP 31
DORA 31
Por que DHCP é essencial em investigação 32
Abusos e problemas relacionados 33
Comandos 33
Fechamento da Parte 1 35
Ferramentas desta parte 35
Erros comuns 35
Falsos positivos comuns 36
Exercícios 36
Laboratório 37
Perguntas de entrevista 37
Checklist de domínio — Parte 1 40
Resumo da Parte 1 40
Respostas comentadas dos exercícios 41
Na Parte 2 42

Se o sumário aparecer vazio, clique com o botão direito sobre ele no Word e escolha "Atualizar campo".

Módulo 1 — Fundamentos de Redes (Parte 1)

Objetivo do módulo

Quase todo alerta de SOC é, no fundo, uma frase com esta forma: **"o endereço A falou com o endereço B, por tal porta, usando tal protocolo, em tal horário, e isso pode não ser normal"**. Se você não entende essa frase, vai copiar e colar campos no ticket sem saber o que eles significam. Este módulo existe para que isso nunca aconteça.

Ao final das duas partes, você deve conseguir:

- Explicar por onde um pacote trafega, da aplicação até o cabo e de volta.
- Dizer em que camada um problema ou ataque acontece e **que equipamento consegue enxergá-lo**.
- Responder rapidamente: esse IP é público ou privado? Está na mesma rede que aquele outro? Quantos hosts cabem nessa sub-rede?
- Descobrir qual máquina tinha um IP num horário específico (DHCP) e qual usuário estava atrás de um IP público (NAT).
- Ler logs de DNS, DHCP, firewall e NAT e saber o que procurar neles.
- Usar comandos básicos de rede no Windows e no Linux para confirmar hipóteses.

> 🎯 **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Você **não** precisa ser engenheiro de redes. Você precisa:
>
> - Saber ler um par **origem → destino** com portas e dizer quem iniciou a conversa.
> - Reconhecer IP privado, público, loopback e APIPA à primeira vista.
> - Saber que **IP não é pessoa**: entre o IP e o usuário existem DHCP, NAT, VPN e proxy, e cada um tem seu log.
> - Saber qual fonte de log enxerga cada camada.
> - Saber quando um problema é de rede (NOC/infra) e quando é de segurança (SOC), e quando é os dois.

1.1 Modelo OSI

O que é e por que existe

O **modelo OSI** (Open Systems Interconnection) é um modelo de referência criado pela ISO no fim dos anos 1970 para organizar a comunicação entre sistemas em **7 camadas**. Cada camada tem uma responsabilidade e conversa apenas com a camada de cima e a de baixo. A ideia é a mesma de uma empresa bem organizada (que você raramente vai encontrar): cada departamento faz sua parte sem precisar saber como os outros trabalham por dentro.

Por que existe: antes de padrões, cada fabricante tinha sua própria forma de fazer computadores conversarem, e nada era compatível. Dividir o problema em camadas permite que uma placa de rede de um fabricante funcione com um sistema operacional de outro e com um navegador de um terceiro.

Por que o SOC se importa: porque o OSI é um **mapa de raciocínio**. Quando você olha um alerta, perguntar "em que camada isso está acontecendo?" diz imediatamente que tipo de equipamento tem visibilidade, que log procurar e que tipo de ataque é plausível.

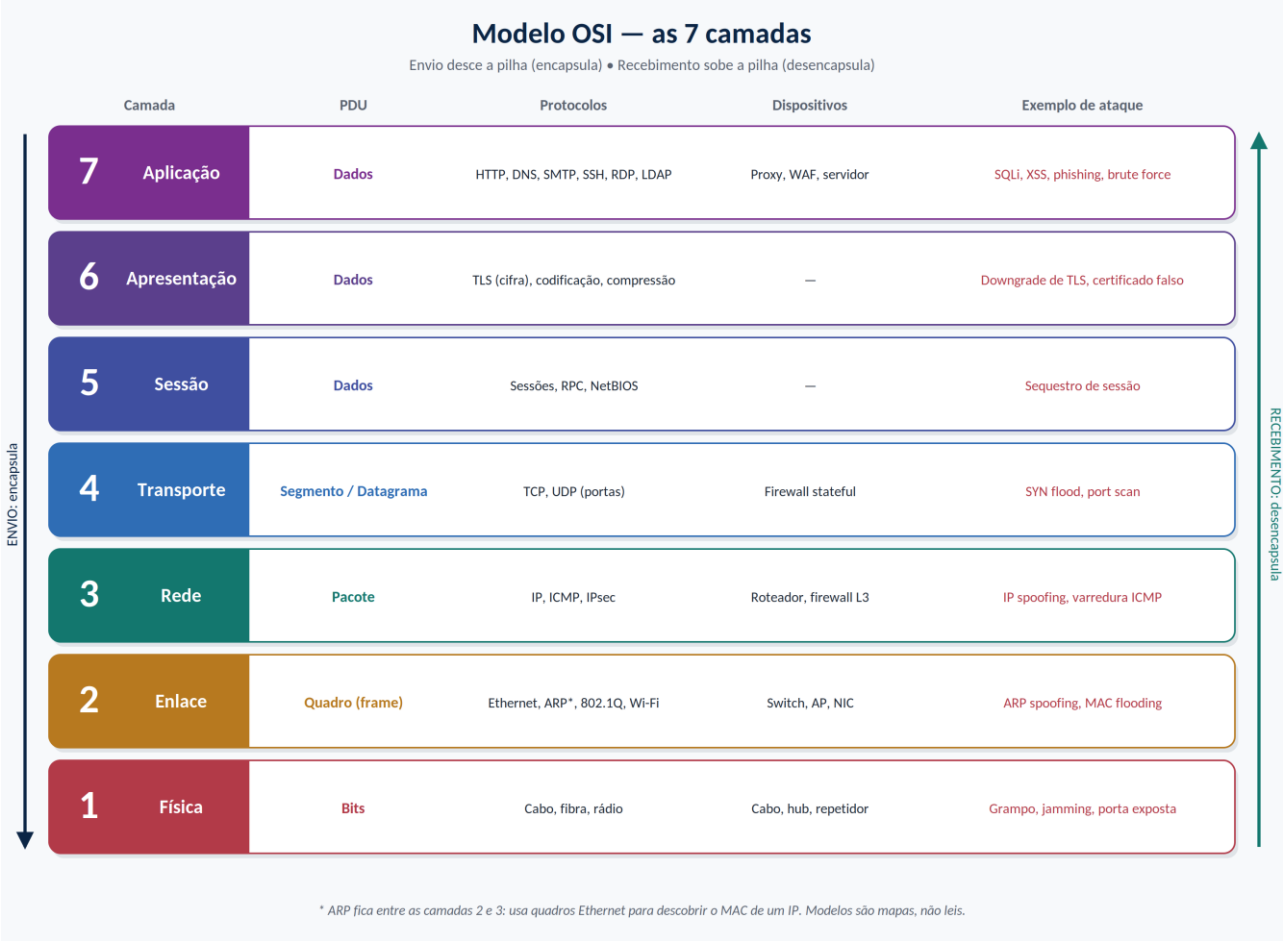


Figura 1.1 — As 7 camadas do modelo OSI, com PDU, protocolos, dispositivos e exemplos de ataque

Unidades de dados (PDU)

Cada camada dá um nome diferente ao "pacote" que manipula. Isso se chama **PDU** (Protocol Data Unit). Parece pedantismo, mas aparece em entrevista e ajuda a ser preciso:

Camada(s)	PDU	O que contém	Exemplo de pergunta de SOC
7, 6, 5	**Dados** (data)	O conteúdo da aplicação: uma requisição HTTP, uma consulta DNS, um e-mail.	Qual URL foi pedida? Qual domínio foi consultado?
4	**Segmento** (TCP) / **Datagrama** (UDP)	Dados + cabeçalho de transporte com portas de origem e destino, números de sequência, flags.	Para qual porta foi? A conexão completou o handshake?
3	**Pacote** (packet)	Segmento + cabeçalho IP com endereço de origem, destino e TTL.	De qual IP veio? Para qual IP foi?
2	**Quadro** (frame)	Pacote + cabeçalho Ethernet com MAC de origem e destino, tag de VLAN e verificação de erro (FCS).	Qual MAC enviou? Em qual VLAN?
1	**Bits**	Sinais elétricos, luz ou rádio representando 0 e 1.	O link caiu? Alguém conectou algo numa porta física?

As camadas em detalhe

Camada 7 — Aplicação

Aspecto	Descrição
Função	Interface entre a rede e os programas que o usuário (ou um serviço) utiliza. Define o "idioma" da conversa: como pedir uma página, enviar um e-mail, resolver um nome.
Principais protocolos	HTTP/HTTPS, DNS, SMTP, IMAP, POP3, FTP, SSH, RDP, SMB, LDAP, SNMP, NTP.
Dispositivos relacionados	Servidores de aplicação, proxy, WAF, gateway de e-mail, NGFW com inspeção de aplicação.
Unidade de dados	Dados.
Exemplos do dia a dia	Navegador pedindo `GET /login`; Outlook enviando e-mail; estação consultando `empresa.com` no DNS.
Possíveis ataques	SQL Injection, XSS, directory traversal, brute force de login web, phishing, abuso de API, DNS tunneling, credential stuffing.
Telemetria / fontes de log	Logs de servidor web (IIS, Apache, Nginx), WAF, proxy, DNS, gateway de e-mail, logs da própria aplicação.
Como aparece no SOC	Alertas de WAF ("SQLi detectado"), proxy ("categoria malware"), e-mail ("phishing"), DNS ("domínio recém-registrado"). É a camada onde a maioria dos ataques **com intenção** fica visível.

Camada 6 — Apresentação

Aspecto	Descrição
Função	Garante que os dados estejam num formato que o destino entenda: codificação de caracteres (UTF-8), compressão e **criptografia**. Na prática moderna, TLS é o exemplo mais citado aqui, embora implementações reais misturem camadas.
Principais protocolos	TLS/SSL (cifra), codificações (ASCII, UTF-8, Base64), formatos (JPEG, MIME).
Dispositivos relacionados	Normalmente implementada em software; NGFW e proxies com inspeção TLS atuam sobre ela.
Unidade de dados	Dados.
Exemplos do dia a dia	O navegador negociando TLS 1.3 com o servidor; um anexo convertido em Base64 dentro do e-mail.
Possíveis ataques	Downgrade de versão TLS, certificados falsos ou autoassinados, ofuscação por Base64 (comum em PowerShell malicioso), exfiltração cifrada.
Telemetria / fontes de log	Logs de TLS do proxy/NGFW (versão, cifra, certificado, SNI), Zeek `ssl.log`, alertas de certificado inválido.
Como aparece no SOC	Alertas como "certificado autoassinado em destino externo" ou "TLS em porta não padrão". Também o motivo de muitos SOCs **não verem o conteúdo** do tráfego: está cifrado.

Camada 5 — Sessão

Aspecto	Descrição
Função	Estabelece, mantém e encerra o "diálogo" entre aplicações: controle de sessões, checkpoints, retomada. No mundo real, muitas dessas funções vivem dentro da própria aplicação.
Principais protocolos	RPC, NetBIOS Session, partes do SMB, controle de sessão de aplicações.
Dispositivos relacionados	Software; servidores de aplicação.
Unidade de dados	Dados.
Exemplos do dia a dia	Uma sessão de compartilhamento de arquivos permanecendo aberta; uma sessão web identificada por cookie.
Possíveis ataques	Sequestro de sessão (session hijacking), roubo de cookie/token de sessão, replay.
Telemetria / fontes de log	Logs de aplicação com IDs de sessão, logs de autenticação, proxies que registram cookies/tokens (raro).
Como aparece no SOC	Investigações de "conta acessada sem senha": token de sessão roubado por infostealer e reutilizado de outro IP. O ID de sessão é a pista.

Camada 4 — Transporte

Aspecto	Descrição
Função	Entrega de dados entre **processos** (não apenas máquinas). Usa **portas** para identificar o serviço. O TCP garante entrega ordenada e confiável; o UDP é rápido e sem garantia.
Principais protocolos	TCP, UDP.
Dispositivos relacionados	Firewall stateful, balanceador de carga L4, IDS/IPS.
Unidade de dados	Segmento (TCP) ou datagrama (UDP).
Exemplos do dia a dia	Conexão de 10.0.0.5:51523 para 203.0.113.80:443; consulta DNS de 10.0.0.5:61002 para 10.0.0.53:53.
Possíveis ataques	SYN flood, port scanning (TCP e UDP), sequestro de conexão TCP, uso de portas padrão para tráfego não padrão.
Telemetria / fontes de log	Logs de firewall (5-tupla, ação, bytes), NetFlow/IPFIX, Zeek `conn.log`, EDR (conexões por processo).
Como aparece no SOC	Alertas de "port scan", "conexão para porta incomum", "muitas conexões negadas". É onde você pergunta **qual serviço** estava envolvido e **se a conexão completou**.

Camada 3 — Rede

Aspecto	Descrição
Função	Endereçamento lógico (IP) e **roteamento** entre redes diferentes. Decide o caminho até o destino, salto a salto.
Principais protocolos	IPv4, IPv6, ICMP, IPsec, protocolos de roteamento (OSPF, BGP).

Aspecto	Descrição
Dispositivos relacionados	Roteador, switch L3, firewall.
Unidade de dados	Pacote.
Exemplos do dia a dia	Pacote de 10.0.0.5 para 203.0.113.80 passando pelo gateway 10.0.0.1; ping para 8.8.8.8.
Possíveis ataques	IP spoofing, varredura de hosts (ping sweep), ataques de fragmentação, sequestro de rota (BGP hijacking), smurf.
Telemetria / fontes de log	Logs de roteador e firewall, NetFlow, ICMP em IDS, tabelas de roteamento.
Como aparece no SOC	Quase todo log de segurança tem IP de origem e destino. Saber se é **interno x interno** (leste-oeste) ou **interno x externo** (norte-sul) muda a análise.

Camada 2 — Enlace

Aspecto	Descrição
Função	Comunicação **dentro da mesma rede local**, usando endereços físicos (MAC). Organiza bits em quadros, detecta erros e separa redes lógicas (VLANs).
Principais protocolos	Ethernet (802.3), Wi-Fi (802.11), 802.1Q (VLAN), ARP (entre 2 e 3), STP, 802.1X (autenticação de porta).
Dispositivos relacionados	Switch, access point, placa de rede (NIC), bridge.
Unidade de dados	Quadro (frame).
Exemplos do dia a dia	Estação entregando um quadro ao MAC do gateway; switch aprendendo em qual porta está cada MAC.
Possíveis ataques	ARP spoofing/poisoning, MAC flooding, MAC spoofing, VLAN hopping, rogue DHCP, ataques a STP, rogue access point.
Telemetria / fontes de log	Logs de switch (MAC flapping, port security, DAI), NAC, controladora Wi-Fi, IDS com visão de LAN, arpwatch.
Como aparece no SOC	Menos frequente na fila de um N1, porque muitos SOCs **não recebem log de switch**. Quando recebem, aparece como "MAC duplicado", "porta desabilitada por port-security" ou "dispositivo não autorizado no NAC".

Camada 1 — Física

Aspecto	Descrição
Função	Transmissão dos bits pelo meio físico: tensão no cobre, pulsos de luz na fibra, ondas de rádio no Wi-Fi. Define conectores, cabos, frequências.
Principais protocolos	Padrões físicos: 1000BASE-T, fibra, 802.11 (parte física), Bluetooth.
Dispositivos relacionados	Cabos, fibras, hubs, repetidores, transceivers, antenas.
Unidade de dados	Bits.

Aspecto	Descrição
Exemplos do dia a dia	Link da porta 12 do switch caindo; sinal Wi-Fi fraco.
Possíveis ataques	Grampo (tapping), jamming de rádio, dispositivo implantado em porta física exposta, destruição de cabo, acesso físico ao rack.
Telemetria / fontes de log	Logs de link up/down no switch, sensores físicos, controle de acesso físico (catraca, CFTV), NAC.
Como aparece no SOC	Raramente vira alerta de SOC diretamente, mas "porta de switch numa sala de reunião ficou up às 23h com um MAC desconhecido" é um alerta muito interessante.

Tabela de referência rápida

Camada	Nome	PDU	Protocolos	Dispositivos	Exemplos de ataque	Fonte de log
7	Aplicação	Dados	HTTP, DNS, SMTP, SSH, RDP, SMB, LDAP	Proxy, WAF, servidores	SQLi, XSS, brute force HTTP, phishing	WAF, proxy, DNS, web server, e-mail
6	Apresentação	Dados	TLS, Base64, MIME	Software, NGFW/proxy TLS	Downgrade TLS, certificado falso, ofuscação	Proxy/NGFW (TLS), Zeek ssl
5	Sessão	Dados	RPC, NetBIOS, sessões	Software	Session hijacking, roubo de token	Logs de aplicação/IdP
4	Transporte	Segmento / Datagrama	TCP, UDP	Firewall stateful, LB	SYN flood, port scan	Firewall, NetFlow, Zeek conn, EDR
3	Rede	Pacote	IP, ICMP, IPsec	Roteador, firewall	IP spoofing, ping sweep	Firewall, roteador, NetFlow, IDS
2	Enlace	Quadro	Ethernet, 802.1Q, ARP, Wi-Fi	Switch, AP, NIC	ARP spoofing, MAC flooding, VLAN hopping	Switch, IDS, NAC, controladora Wi-Fi
1	Física	Bits	Cobre, fibra, rádio	Cabos, hubs, antenas	Grampo, jamming, porta exposta	Link up/down, acesso físico

Por que o OSI é útil se não é perfeito

O OSI é um **modelo**, e modelos simplificam. A internet real roda em TCP/IP, várias tecnologias ficam "entre" camadas (ARP entre 2 e 3, TLS entre 4 e 7) e as camadas 5 e 6 quase sempre vivem dentro da aplicação. Mesmo assim ele continua sendo usado por três motivos:

- **Linguagem comum:** "é problema de camada 2" é entendido por qualquer profissional de rede ou segurança no mundo.
- **Isolamento de problemas:** se o ping (camada 3) funciona e o site não abre, o problema está acima: porta, firewall, TLS ou aplicação.
- **Mapa de visibilidade:** cada camada tem equipamentos e logs próprios. Um firewall tradicional que só vê camadas 3 e 4 nunca vai detectar um SQL Injection, que é camada 7. Para isso existe o WAF.

MOMENTO SOC

Pergunta de entrevista clássica: "Em que camada atua um firewall?"

Resposta de quem decorou: "Camada 3."

Resposta de quem entendeu: "Depende. Um firewall de pacotes tradicional decide com base em IP e porta, camadas 3 e 4. Um NGFW identifica aplicação e usuário, chegando à camada 7. Um WAF é especializado em HTTP, camada 7."

O entrevistador não quer o número. Quer ver se você entende o que o equipamento **enxerga**.

Leitura de SOC	
O que procuro	Em que camada está o comportamento do alerta? Que equipamentos atuam nessa camada? Tenho log deles?
Pode ser benigno	Varredura de camada 4 feita pelo scanner autorizado; erros de camada 1/2 por manutenção física.
Pode ser suspeito	Atividade de camada 2 anômala (MAC do gateway mudou), varredura vinda de host de usuário, padrões de ataque de camada 7 no WAF.
Próximo passo	Identificar a fonte de log adequada à camada e buscar os eventos correlatos do mesmo par origem/destino.
Quando escalo	Quando houver sinais em múltiplas camadas apontando para o mesmo ativo (ex.: ARP anômalo + conexões a destinos externos novos) ou quando não houver visibilidade na camada necessária para concluir.

1.2 Modelo TCP/IP

Se o OSI é o mapa de raciocínio, o **TCP/IP** é a estrada de verdade. É o conjunto de protocolos que a internet e praticamente todas as redes corporativas usam. Ele tem **4 camadas** (algumas referências usam 5, separando física e enlace):

Camada TCP/IP	Função	Protocolos	Equivale no OSI
Aplicação	Tudo que a aplicação precisa: formato, cifra, sessão e o protocolo em si.	HTTP, DNS, TLS, SSH, SMTP, SMB, LDAP, RDP	7, 6 e 5
Transporte	Entrega entre processos via portas; confiabilidade (TCP) ou velocidade (UDP).	TCP, UDP	4
Internet	Endereçamento IP e roteamento entre redes.	IPv4, IPv6, ICMP, IPsec	3
Acesso à Rede (Network Access / Link)	Entrega no meio local: quadros, MAC, meio físico.	Ethernet, Wi-Fi, ARP, 802.1Q	2 e 1

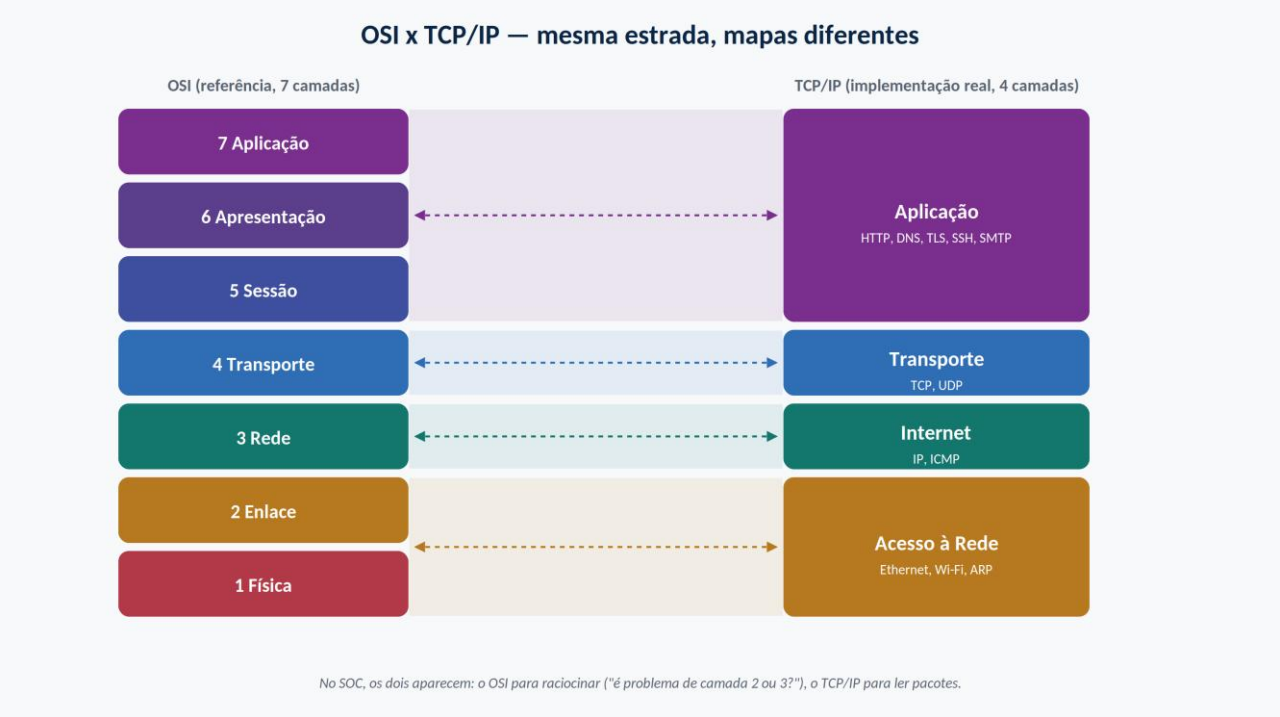


Figura 1.2 — Equivalência entre as camadas do modelo OSI e do modelo TCP/IP

OSI x TCP/IP: diferenças que importam

Aspecto	OSI	TCP/IP
Natureza	Modelo de referência teórico	Pilha de protocolos implementada
Camadas	7	4 (ou 5)
Uso no SOC	Raciocinar sobre visibilidade e tipo de ataque	Ler pacotes, logs e cabeçalhos reais
Sessão e apresentação	Camadas próprias	Dentro da camada de aplicação
Quem criou	ISO	DARPA / IETF (RFCs)

> **DICA**
>
> Na entrevista, mostre que conhece os dois e explique por que usa cada um. "Uso o OSI para pensar e o TCP/IP para ler o tráfego" é uma resposta curta e madura.

1.3 Encapsulamento e o caminho completo de uma requisição

O que é encapsulamento

Encapsulamento é o processo em que cada camada, ao enviar, **adiciona seu próprio cabeçalho** ao que recebeu da camada de cima. É como enviar um documento: você coloca a carta num envelope (transporte), o envelope numa caixa com endereço (rede), a caixa num caminhão com placa (enlace) e o caminhão anda pela estrada (física). Quem recebe faz o caminho inverso: **desencapsulamento**.

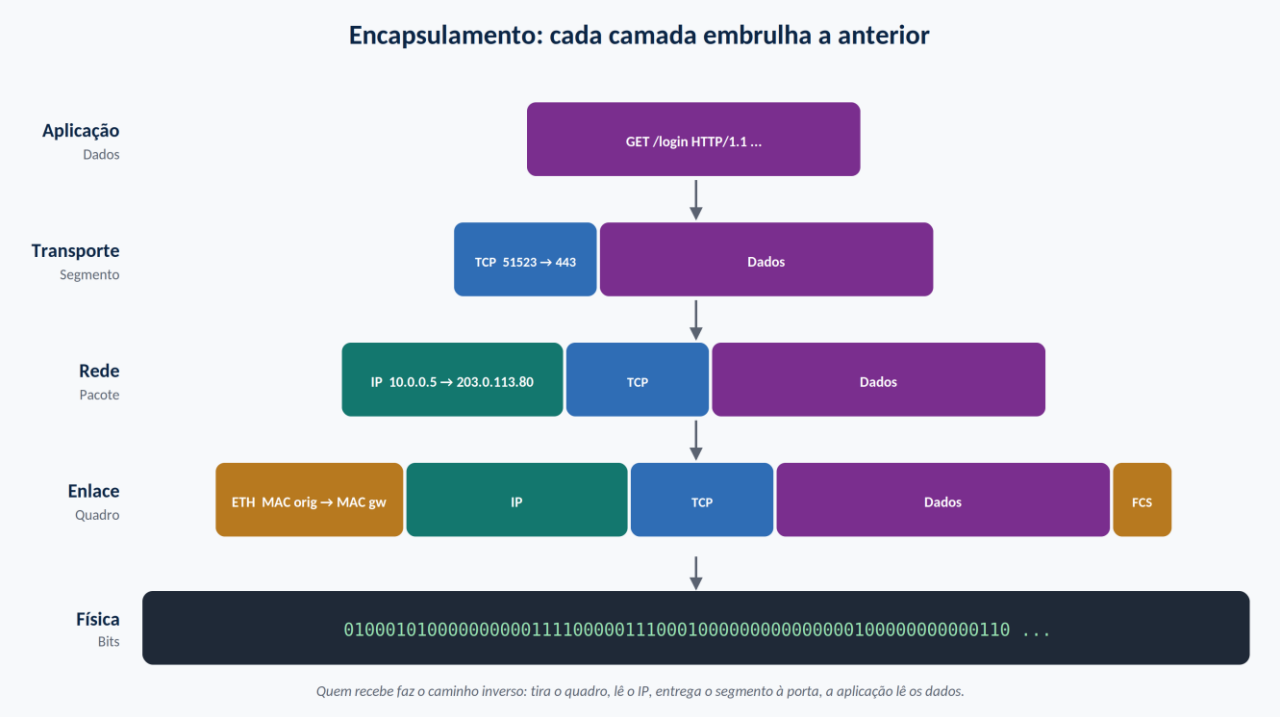


Figura 1.3 — Encapsulamento: dados → segmento → pacote → quadro → bits

```
Envio (desce a pilha)          Recebimento (sobe a pilha)

Aplicação   [Dados]                        ↑ a aplicação lê os dados
   ↓                                       ↑ TCP entrega à porta 443
Transporte  [TCP | Dados]                  ↑ IP confere destino
   ↓                                       ↑ Ethernet confere MAC/FCS
Rede        [IP | TCP | Dados]             ↑ bits viram quadro
   ↓
Enlace      [ETH | IP | TCP | Dados | FCS]
   ↓
Física      010001010000...
```

> 🎯 **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Um detalhe que pega muita gente: **o MAC muda a cada salto, o IP (em geral) não**.
>
> Quando sua estação fala com um site na internet, o quadro sai com MAC de destino = **MAC do gateway**, não do servidor. O IP de destino continua sendo o do servidor. Cada roteador no caminho cria um quadro novo. Por isso **MAC só tem significado dentro da rede local**, e um log de firewall de borda nunca vai mostrar o MAC da estação de origem.
>
> Exceção importante: o **NAT** muda o IP (seção 1.8).

Passo a passo: o que acontece quando o usuário abre https://empresa.com

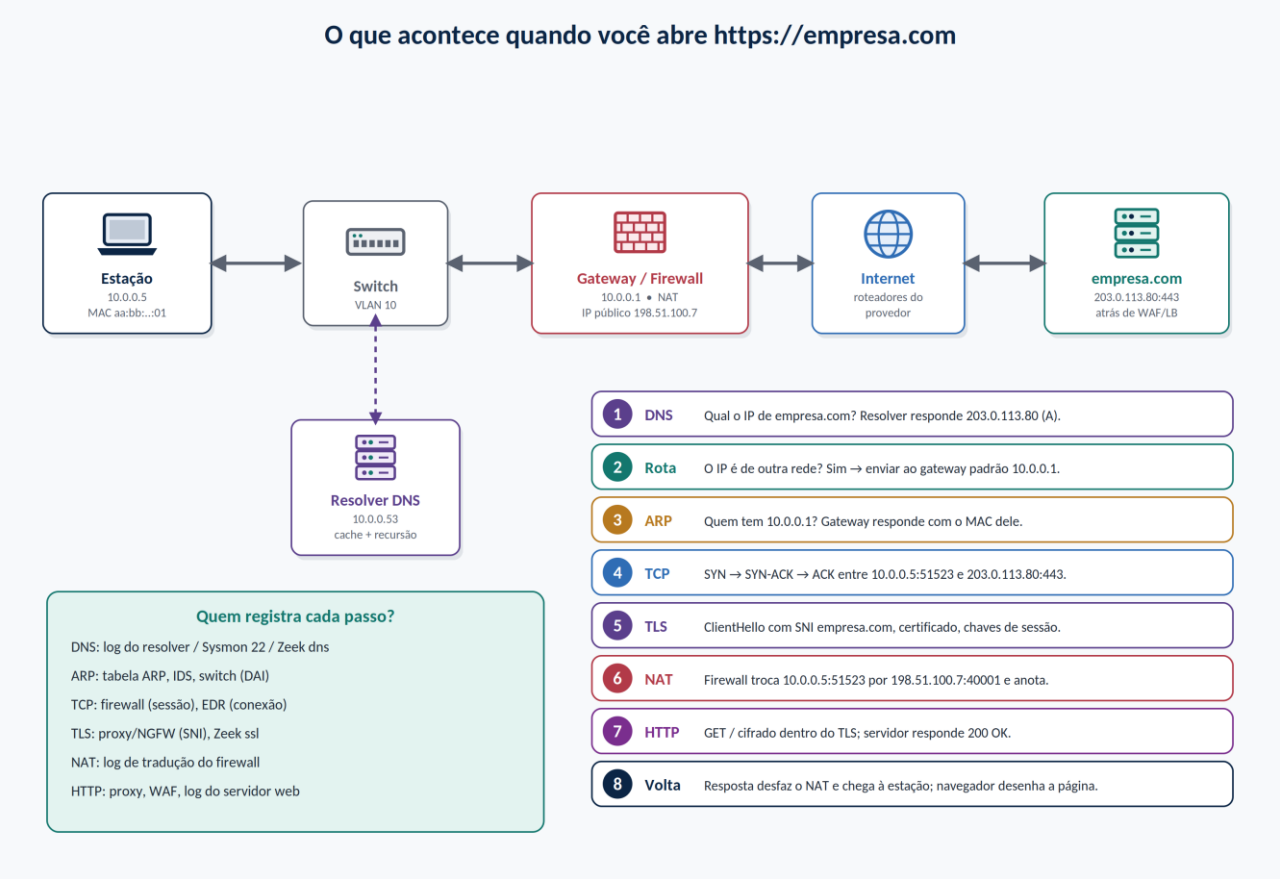


Figura 1.4 — Os oito passos de um acesso HTTPS e quem registra cada um

Considere a estação `10.0.0.5/24`, gateway `10.0.0.1`, resolver DNS interno `10.0.0.53`, e o site `empresa.com` em `203.0.113.80`.

1. **Cache local:** o navegador e o sistema operacional verificam se já sabem o IP de `empresa.com` (cache DNS, arquivo `hosts`). Se sim, pulam o passo 2.
2. **DNS lookup:** a estação envia uma consulta DNS (UDP/53) ao resolver `10.0.0.53`: "qual o registro A de empresa.com?". O resolver responde do cache ou pergunta à hierarquia DNS (seção 1.9). Resposta: `203.0.113.80`.
3. **Decisão de roteamento:** a estação compara `203.0.113.80` com sua própria rede (`10.0.0.0/24`). Não é da mesma rede, então o pacote deve ir para o **gateway padrão** `10.0.0.1`.
4. **ARP:** para montar o quadro, a estação precisa do MAC do gateway. Se não estiver no cache ARP, envia em broadcast: "quem tem 10.0.0.1?". O gateway responde com seu MAC.
5. **TCP handshake:** a estação escolhe uma **porta de origem efêmera** (ex.: 51523) e envia **SYN** para `203.0.113.80:443`. O servidor responde **SYN-ACK**, a estação responde **ACK**. Conexão estabelecida.
6. **NAT:** ao passar pelo firewall de borda, o IP privado `10.0.0.5:51523` é trocado pelo IP público da empresa (ex.: `198.51.100.7:40001`). O firewall guarda essa tradução numa tabela.
7. **Roteamento na internet:** o pacote atravessa vários roteadores de provedores; cada um olha apenas o IP de destino e decide o próximo salto.
8. **TLS:** dentro da conexão TCP, a estação envia o **ClientHello**, incluindo o **SNI** (Server Name Indication) com o nome `empresa.com` em texto claro (na maioria dos casos). O servidor envia seu **certificado**. Ambos derivam chaves de sessão. A partir daqui o conteúdo é cifrado.

9. **HTTP:** o navegador envia `GET / HTTP/1.1` (ou HTTP/2) com cabeçalhos como `Host`, `User-Agent` e `Cookie`, tudo dentro do TLS.
10. **Servidor:** muitas vezes o IP público pertence a um **WAF, CDN ou balanceador de carga**, que repassa a requisição a um servidor interno. O servidor processa e devolve `200 OK` com o HTML.
11. **Resposta:** volta pelo mesmo caminho. O firewall consulta a tabela de NAT, troca `198.51.100.7:40001` de volta para `10.0.0.5:51523`, e o quadro final é entregue ao MAC da estação.
12. **Desencapsulamento:** a placa de rede aceita o quadro, o IP confere o destino, o TCP entrega à porta 51523, o TLS decifra, e o navegador renderiza a página. Tudo isso em algumas dezenas de milissegundos.

Quem enxerga o quê nesse fluxo

Passo	Evidência possível	Fonte de log	O que NÃO mostra
DNS	Estação X consultou `empresa.com` às 10:02:01	Resolver DNS, Sysmon Event ID 22, Zeek dns.log	Se a estação de fato conectou
ARP	IP ↔ MAC na LAN	Cache ARP, switch com DAI, IDS	Nada fora da rede local
TCP	Conexão 10.0.0.5:51523 → 203.0.113.80:443 permitida, bytes trocados	Firewall, NetFlow, EDR (com processo!)	Conteúdo
NAT	10.0.0.5:51523 → 198.51.100.7:40001	Log de NAT do firewall	Qual usuário (precisa de AD/proxy)
TLS	SNI `empresa.com`, versão, certificado	Proxy, NGFW, Zeek ssl.log	URL completa e conteúdo, sem inspeção TLS
HTTP	URL, método, código, user-agent, usuário	Proxy (com inspeção), WAF, log do servidor web	O que o processo fez na estação
Estação	Processo `chrome.exe` abriu a conexão	EDR, Sysmon Event ID 3	Se o usuário pretendia acessar

> **MOMENTO SOC**
>
> O EDR é o único da lista que costuma dizer **qual processo** abriu a conexão.
>
> Firewall: "10.0.0.5 falou com 203.0.113.80:443." Ok, e daí?
>
> EDR: "foi o `chrome.exe`, filho de `explorer.exe`." Usuário navegando.
>
> EDR (outro dia): "foi o `rundll32.exe`, filho de `winword.exe`." Agora sim temos assunto.
>
> Mesmo IP, mesma porta, histórias completamente diferentes.

1.4 Endereçamento IP

IPv4

Um endereço **IPv4** tem **32 bits**, escritos como 4 números decimais (octetos) de 0 a 255 separados por pontos: `192.168.1.10`. Cada octeto representa 8 bits. São cerca de 4,3 bilhões de endereços possíveis, o que acabou faz tempo. Por isso existem IPs privados, NAT e IPv6.

```
192      .  168      .  1        .  10
11000000 .  10101000 .  00000001 .  00001010
```

IPv6 (o básico para não travar)

IPv6 tem **128 bits**, escritos em 8 grupos hexadecimais: `2001:0db8:0000:0000:0000:ff00:0042:8329`. Zeros à esquerda podem ser omitidos e uma sequência de grupos zerados pode virar `::` uma única vez: `2001:db8::ff00:42:8329`.

Tipo IPv6	Prefixo / exemplo	Equivalente aproximado em IPv4
Loopback	`::1`	`127.0.0.1`
Link-local	`fe80::/10`	APIPA `169.254.0.0/16` (mas usado normalmente, não só em falha)
Unique local (privado)	`fc00::/7` (na prática `fd00::/8`)	Faixas privadas RFC 1918
Global unicast (público)	`2000::/3`	IP público
Multicast	`ff00::/8`	`224.0.0.0/4`

> **NA VIDA REAL**
>
> Muitos ambientes têm IPv6 **habilitado nas estações** mesmo sem usá-lo oficialmente. Resultado: tráfego IPv6 que nenhuma regra do SIEM considera, porque todas as consultas filtram `src_ip` com formato IPv4.
>
> Se você vê `fe80::` em logs do Windows, não é invasão alienígena. É link-local, presente em praticamente toda interface.

Tipos de endereço que o N1 precisa reconhecer à primeira vista

Tipo	Faixa	O que significa	Leitura de SOC

Privado (RFC 1918)	`10.0.0.0/8`
	`172.16.0.0/12` (172.16 a 172.31)
	`192.168.0.0/16`
		Uso interno; não é roteado na internet.	Origem interna. Para saber quem é: DHCP, CMDB, EDR.

Público	Todo o resto que não é reservado	Roteável na internet.	Consultar WHOIS, ASN, reputação, geolocalização.
Loopback	`127.0.0.0/8` (normalmente 127.0.0.1)	A própria máquina falando com ela mesma.	Conexões locais entre processos. Geralmente benigno, mas também usado por proxies locais e alguns malwares.
APIPA (link-local)	`169.254.0.0/16`	Windows não conseguiu IP via DHCP e se autoatribuiu.	Problema de DHCP/rede. Host provavelmente sem comunicação normal.
CGNAT	`100.64.0.0/10`	Faixa usada por provedores para NAT em grande escala.	Comum em VPN de usuários domésticos; não é IP "público" do usuário.

Tipo	Faixa	O que significa	Leitura de SOC
Broadcast	Último endereço da sub-rede; `255.255.255.255`	Para todos os hosts da rede local.	DHCP Discover e ARP usam. Volume anômalo pode indicar problema ou varredura.
Multicast	`224.0.0.0/4`	Para um grupo de hosts interessados.	mDNS (`224.0.0.251`), LLMNR (`224.0.0.252`), SSDP. Comum e ruidoso.
Documentação	`192.0.2.0/24`, `198.51.100.0/24`, `203.0.113.0/24`	Reservado para exemplos.	Se aparecer em produção, alguém copiou um exemplo. Usamos neste guia de propósito.
Endereço "nenhum"	`0.0.0.0`	Qualquer endereço / indefinido.	Em `netstat`, serviço escutando em todas as interfaces. Em log de SIEM, frequentemente **parser quebrado**.

Unicast, broadcast e multicast

- **Unicast:** um para um. A esmagadora maioria do tráfego (sua estação falando com um servidor).
- **Broadcast:** um para todos da rede local. Não atravessa roteadores. Usado por ARP e DHCP Discover.
- **Multicast:** um para um grupo inscrito. Usado por descoberta de serviços, streaming, protocolos de roteamento.
- **Anycast** (bônus): o mesmo IP anunciado em vários lugares; você chega ao mais próximo. Resolvers públicos como `8.8.8.8` e `1.1.1.1` usam.

CIDR, máscara e sub-redes

Um IP sozinho não diz qual é a rede. Para isso existe a **máscara de rede**, que separa a parte de **rede** da parte de **host**. A notação **CIDR** (Classless Inter-Domain Routing) escreve a máscara como o número de bits de rede: `/24` significa "os primeiros 24 bits identificam a rede".



Figura 1.5 — CIDR em bits: parte de rede, parte de host e blocos de uma /28

Para cada sub-rede, quatro valores importam:

- **Endereço de rede:** o primeiro endereço (todos os bits de host em 0). Identifica a rede; não é atribuído a hosts.
- **Broadcast:** o último endereço (todos os bits de host em 1).
- **Faixa de hosts:** tudo entre os dois.
- **Quantidade de hosts:** `2^(bits de host) − 2` (descontando rede e broadcast).

CIDR	Máscara	Endereços	Hosts úteis	Onde aparece
/8	255.0.0.0	16.777.216	16.777.214	`10.0.0.0/8` inteiro
/16	255.255.0.0	65.536	65.534	Rede de um site grande
/22	255.255.252.0	1.024	1.022	VLAN grande de usuários / Wi-Fi
/23	255.255.254.0	512	510	VLAN de usuários
/24	255.255.255.0	256	254	A mais comum em LAN
/25	255.255.255.128	128	126	Metade de uma /24
/26	255.255.255.192	64	62	Rede de servidores pequena
/27	255.255.255.224	32	30	DMZ pequena
/28	255.255.255.240	16	14	Bloco de IPs públicos de empresa
/29	255.255.255.248	8	6	Link com provedor
/30	255.255.255.252	4	2	Link ponto a ponto entre roteadores
/32	255.255.255.255	1	1 (o próprio)	Um único host em regras de firewall e IOCs

O truque do "tamanho do bloco"

Você não precisa converter tudo para binário no dia a dia. Basta saber o **tamanho do bloco** no octeto "interessante" (o que não é 255 nem 0 na máscara): **256 − valor da máscara nesse octeto**.

```
Exemplo: 10.10.10.37/28
Máscara /28 = 255.255.255.240  → octeto interessante: o 4º (240)
Tamanho do bloco = 256 − 240 = 16
Blocos no 4º octeto: 0, 16, 32, 48, 64 ...
37 está entre 32 e 47  →  rede 10.10.10.32/28
Hosts: 10.10.10.33 a 10.10.10.46   Broadcast: 10.10.10.47

Exemplo: 172.20.13.200/22
Máscara /22 = 255.255.252.0  → octeto interessante: o 3º (252)
Bloco = 256 − 252 = 4  → 0, 4, 8, 12, 16 ...
13 está entre 12 e 15  →  rede 172.20.12.0/22
Hosts: 172.20.12.1 a 172.20.15.254   Broadcast: 172.20.15.255
```

As três perguntas que o N1 precisa responder

Pergunta	Como responder	Exemplo
É público ou privado?	Decorar as três faixas RFC 1918 e as especiais (loopback, APIPA, CGNAT).	`172.31.4.9` é privado (está em 172.16–172.31). `172.32.4.9` é **público**. Essa pegadinha cai em entrevista.
Pertence à mesma rede?	Calcular a rede de cada IP com a máscara e comparar.	`192.168.1.130/25` e `192.168.1.100/25`: a /25 divide em .0–.127 e .128–.255. **Redes diferentes**: precisam de roteador para conversar.
Quantos hosts existem?	`2^(32 - prefixo) - 2`.	/26 → 2^6 − 2 = 62 hosts.

> **NA VIDA REAL**
>
> Regra de firewall: liberar `10.20.0.0/16` para o servidor de pagamentos.
>
> Intenção: liberar a rede de servidores `10.20.0.0/24`.
>
> Resultado: 65.534 endereços liberados, incluindo a VLAN de convidados que alguém criou em `10.20.200.0/24`.
>
> Um dígito no CIDR é a diferença entre segmentação e decoração.

Comandos

```
# Windows
ipconfig                # IP, máscara, gateway por interface
ipconfig /all           # + MAC, DNS, servidor DHCP, lease
Get-NetIPAddress        # PowerShell: endereços IPv4 e IPv6
Get-NetIPConfiguration  # PowerShell: visão resumida com gateway e DNS

# Linux
ip a                    # endereços de todas as interfaces
ip -4 addr show eth0    # apenas IPv4 de uma interface
ipcalc 10.10.10.37/28   # calcula rede, broadcast e hosts (pacote ipcalc)

# Python (qualquer sistema) — ótima calculadora de bolso
python3 -c "import ipaddress as i; n=i.ip_network('10.10.10.37/28', strict=False); print(n,
n.broadcast_address, n.num_addresses-2)"
python3 -c "import ipaddress as i; print(i.ip_address('172.32.4.9').is_private)"
```

Leitura de SOC	
O que procuro	Origem e destino são internos, externos ou especiais? A comunicação é entre redes que deveriam conversar?
Pode ser benigno	Tráfego interno entre estação e servidor de arquivos; multicast de descoberta (mDNS, LLMNR, SSDP); APIPA em host com cabo desconectado.
Pode ser suspeito	Estação de usuário falando diretamente com rede de gerência; IP público "interno" que não pertence à empresa; tráfego para faixa de documentação ou endereço inválido (possível spoofing ou erro de parser).
Próximo passo	Classificar cada IP (privado, público, especial), calcular a sub-rede, consultar a documentação de VLANs/CMDB para saber a que segmento pertence.

Leitura de SOC	
Quando escalo	Comunicação entre segmentos que a política diz que não deveriam se falar, especialmente envolvendo servidores críticos ou rede de gerência.

1.5 MAC e ARP

Endereço MAC

O **MAC address** (Media Access Control) é o endereço de **camada 2** de uma interface de rede: 48 bits em hexadecimal, como `00:1A:2B:3C:4D:5E` (Linux) ou `00-1A-2B-3C-4D-5E` (Windows). Os **3 primeiros bytes** identificam o fabricante (**OUI**). Consultar o OUI ajuda a descobrir se aquele dispositivo misterioso é um notebook Dell, uma impressora HP, uma VM VMware ou um Raspberry Pi escondido debaixo de uma mesa.

- O MAC só tem significado **na rede local**; não atravessa roteadores.
- Pode ser **alterado por software** facilmente (MAC spoofing). Não é identidade forte.
- Sistemas modernos usam **MAC aleatório** em Wi-Fi por privacidade, o que bagunça inventários e logs de controladora.
- `FF:FF:FF:FF:FF:FF` é o MAC de broadcast.

ARP — Address Resolution Protocol

O problema: a estação sabe o IP de destino (ou do gateway), mas para montar o quadro Ethernet precisa do **MAC**. **ARP** descobre o MAC correspondente a um IP na rede local.

```
1. ARP Request (broadcast, para FF:FF:FF:FF:FF:FF)
   "Quem tem 192.168.1.1? Responda para 192.168.1.20 (aa:aa:aa:aa:aa:20)"

2. ARP Reply (unicast, só para quem perguntou)
   "192.168.1.1 está em gg:gg:gg:gg:gg:01"

3. A estação grava no ARP cache por alguns minutos e passa a enviar
   quadros para gg:gg:gg:gg:gg:01 sempre que o destino for o gateway.
```

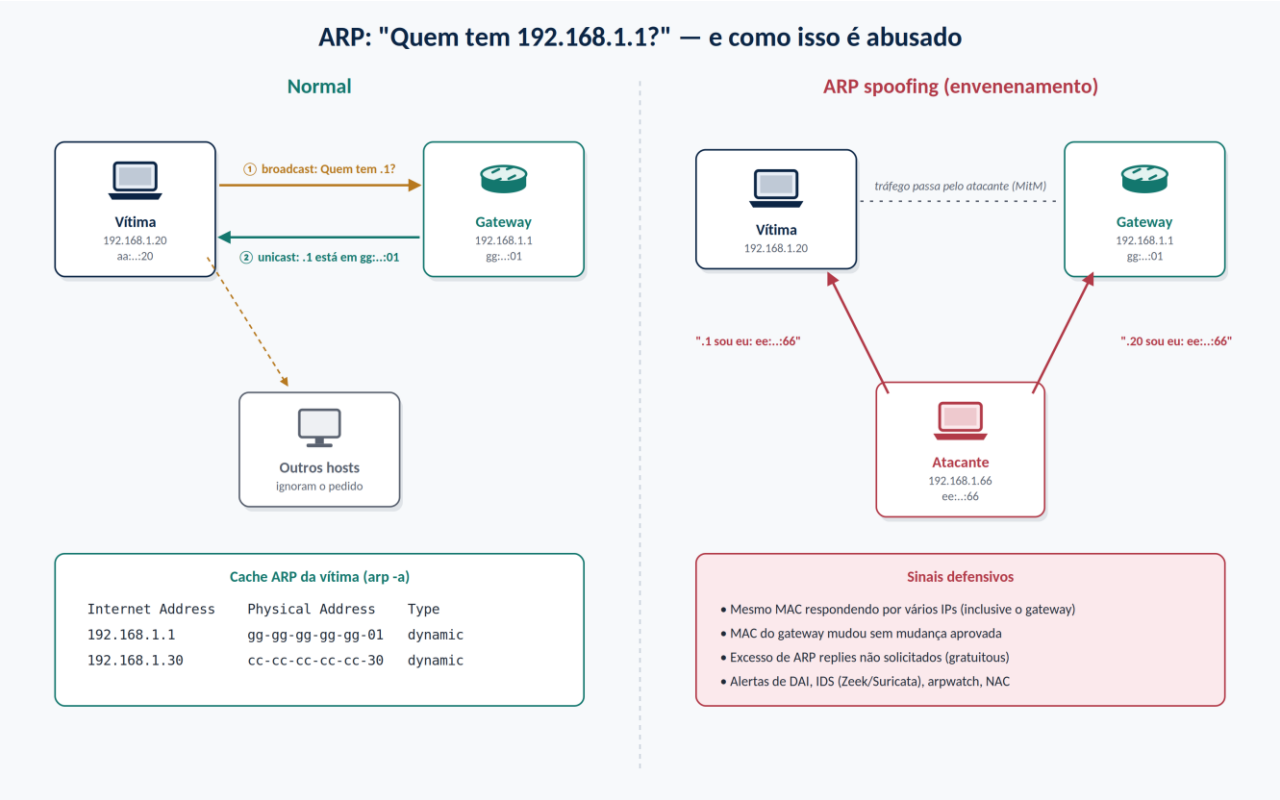


Figura 1.6 — ARP normal à esquerda e ARP spoofing à direita, com sinais defensivos

ARP spoofing (envenenamento de ARP)

Como funciona: o ARP **não tem autenticação**. Qualquer host pode enviar uma resposta ARP dizendo "o IP do gateway sou eu". As vítimas atualizam seu cache e passam a enviar o tráfego para o atacante, que o repassa ao gateway verdadeiro (para não quebrar nada) enquanto observa ou altera o conteúdo. É um ataque **man-in-the-middle (MitM)** de rede local: exige que o atacante esteja no mesmo segmento.

Sinais defensivos:

- Um **mesmo MAC associado a vários IPs**, especialmente ao IP do gateway.
- **MAC do gateway mudou** no cache de várias estações sem mudança aprovada.
- Excesso de **ARP replies não solicitados** (gratuitous ARP) de um host de usuário.
- Alertas de **Dynamic ARP Inspection (DAI)** no switch, de IDS (Suricata/Zeek), de NAC ou ferramentas como arpwatch.
- Usuários reclamando de certificado inválido em vários sites ao mesmo tempo (MitM tentando interceptar TLS).

Logs relacionados

```
# arpwatch (Linux, syslog)
Sep 14 10:22:31 sensor01 arpwatch: flip flop 192.168.1.1 ee:ee:ee:ee:ee:66 (gg:gg:gg:gg:gg:01)
eth0

# Switch Cisco com Dynamic ARP Inspection
%SW_DAI-4-DHCP_SNOOPING_DENY: 1 Invalid ARPs (Res) on Gi1/0/14, vlan 10.
([ee:ee:ee:ee:ee:66/192.168.1.1/aa:aa:aa:aa:aa:20/192.168.1.20/10:22:31 UTC Sep 14 2026])

# Suricata (eve.json, resumido)
```

```
{"event_type":"alert","src_ip":"192.168.1.66","alert":{"signature":"ET POLICY Possible ARP spoofing"}}
```

Comandos

```
# Windows
arp -a                        # cache ARP
Get-NetNeighbor -AddressFamily IPv4   # PowerShell

# Linux
ip neigh                      # cache ARP/vizinhos
arp -n                        # formato antigo (net-tools)

# Procurar o mesmo MAC em vários IPs (Linux)
ip neigh | awk '{print $5}' | sort | uniq -d
```

Leitura de SOC	
O que procuro	Mesmo MAC para vários IPs, mudança de MAC do gateway, volume anormal de ARP, OUI incompatível com o tipo de ativo.
Pode ser benigno	Cluster/failover (VRRP/HSRP) movendo IP virtual entre equipamentos; troca de hardware do gateway em janela aprovada; VMs migrando de host.
Pode ser suspeito	Estação de usuário anunciando o IP do gateway; MAC de fabricante de placa USB/Raspberry Pi respondendo por IP de servidor; alertas de DAI repetidos na mesma porta.
Próximo passo	Identificar porta de switch e host do MAC suspeito (tabela MAC, NAC, DHCP), verificar se há mudança aprovada, checar EDR do host.
Quando escalo	Indício de MitM na rede local é **escalonamento imediato**: o atacante já está dentro, no mesmo segmento.

1.6 Switching e VLAN

Switch e tabela MAC

O **switch** é o equipamento de camada 2 que conecta os dispositivos de uma rede local. Ele **aprende** em qual porta está cada MAC observando o MAC de origem dos quadros que chegam, e grava isso na **tabela MAC** (CAM table). Quando chega um quadro, ele olha o MAC de destino e envia **apenas para a porta correta**. Se não conhece o destino, envia para todas as portas da VLAN (flooding).

```
Tabela MAC (show mac address-table)
VLAN  MAC Address        Type      Port
10    aaaa.aaaa.aa20     DYNAMIC   Gi1/0/5
10    gggg.gggg.gg01     DYNAMIC   Gi1/0/48  (uplink)
20    cccc.cccc.cc30     DYNAMIC   Gi1/0/12
```

Para o SOC, a tabela MAC responde a uma pergunta valiosa: **em que porta física (e, portanto, em que sala ou mesa) está aquele dispositivo?**

VLAN, portas access e trunk, 802.1Q

Uma **VLAN** (Virtual LAN) divide um switch físico em várias redes lógicas isoladas. Hosts em VLANs diferentes **não se comunicam diretamente**: o tráfego precisa passar por um equipamento de camada 3 (roteador ou firewall), onde pode ser filtrado e registrado.

- **Porta access:** pertence a uma única VLAN. É onde ligamos estações, impressoras, servidores. O dispositivo nem sabe que existe VLAN.
- **Porta trunk:** transporta várias VLANs ao mesmo tempo, usada entre switches ou entre switch e firewall/roteador.
- **802.1Q:** o padrão que insere uma **tag** de 4 bytes no quadro Ethernet indicando a VLAN (ID de 1 a 4094) em portas trunk.
- **Native VLAN:** VLAN cujo tráfego trafega sem tag no trunk. Configuração descuidada aqui é o que permite VLAN hopping.

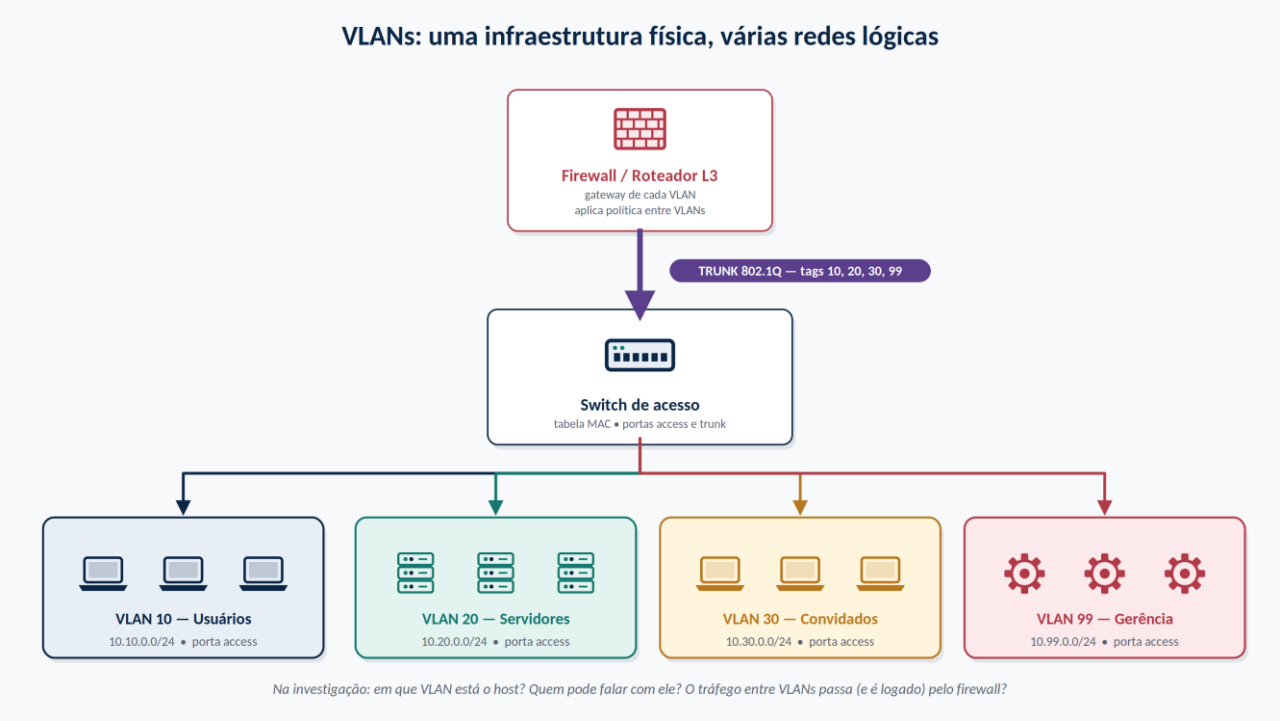


Figura 1.7 — Segmentação com VLANs: trunk 802.1Q até o firewall, portas access por segmento

Segmentação e por que VLAN importa em investigação

Segmentação é dividir a rede para limitar quem fala com quem. É uma das defesas mais eficazes contra movimento lateral: se a VLAN de usuários não alcança a rede de servidores por SMB, um ransomware numa estação tem muito menos para criptografar.

Pergunta de investigação	Por que a VLAN responde
Esse host poderia ter alcançado o servidor?	Se estão em VLANs diferentes, o tráfego passou pelo firewall: **procure o log ali**.
Por que não há log dessa comunicação no firewall?	Porque os dois estão **na mesma VLAN**: o tráfego foi direto pelo switch (leste-oeste sem inspeção). Só EDR ou NetFlow interno mostram.
Esse dispositivo deveria estar aqui?	Uma câmera IP na VLAN de servidores ou um notebook na VLAN de gerência é achado de segurança por si só.
Qual o alcance de um host comprometido?	A VLAN e as regras entre VLANs definem o "raio de explosão".

Pergunta de investigação	Por que a VLAN responde
Visitante pode ter acessado algo interno?	Se a VLAN de convidados está bem isolada, não. Se "está quase isolada", você tem trabalho.

Ataques de camada 2 relacionados (visão defensiva)

Ataque	Ideia	Sinal defensivo
MAC flooding	Encher a tabela MAC com MACs falsos para o switch passar a inundar todas as portas.	Explosão de MACs aprendidos numa porta; alertas de port-security.
MAC spoofing	Assumir o MAC de outro dispositivo (ex.: para burlar NAC).	MAC flapping (mesmo MAC alternando entre portas).
VLAN hopping	Enviar quadros com tag dupla ou negociar trunk para alcançar outra VLAN.	Porta de usuário negociando trunk (DTP); quadros com tag dupla no IDS.
Rogue DHCP	Servidor DHCP não autorizado entregando gateway/DNS do atacante.	Alertas de DHCP snooping; hosts com gateway ou DNS inesperado.

Logs relacionados

```
%SW_MATM-4-MACFLAP_NOTIF: Host 0011.2233.4455 in vlan 10 is flapping between port Gi1/0/5 and
port Gi1/0/22
%PORT_SECURITY-2-PSECURE_VIOLATION: Security violation occurred, caused by MAC 00e0.4c68.0001
on port Gi1/0/31.
%DHCP_SNOOPING-5-DHCP_SNOOPING_UNTRUSTED_PORT: DHCP_SNOOPING drop message on untrusted port
Gi1/0/17, message type: DHCPOFFER
%LINK-3-UPDOWN: Interface GigabitEthernet1/0/31, changed state to up
```

NA VIDA REAL

Documentação de VLANs: planilha de 2019.

VLAN 30: "Convidados".

Realidade: VLAN 30 também tem as câmeras, o relógio de ponto e um servidor que "era temporário".

Antes de afirmar no ticket "o host está isolado na VLAN de convidados", confirme com quem administra a rede. Por escrito.

Leitura de SOC	
O que procuro	VLAN do host envolvido, se o tráfego cruzou segmentos (e por qual firewall), dispositivos em VLAN inadequada, eventos de port-security e MAC flapping.
Pode ser benigno	Notebook mudando de porta (docking station), VM migrando, link up/down em horário de expediente numa sala com rotatividade.
Pode ser suspeito	Porta de usuário negociando trunk; MAC desconhecido em porta de área restrita fora de horário; rogue DHCP; dispositivo de usuário na VLAN de gerência.
Próximo passo	Localizar porta física e dispositivo, consultar NAC/CMDB, verificar se o equipamento é conhecido, acionar time de redes conforme procedimento.

Leitura de SOC	
Quando escalo	Dispositivo não autorizado conectado em segmento sensível, rogue DHCP ou sinais de VLAN hopping.

1.7 Roteamento

Roteamento é o processo de encaminhar pacotes **entre redes diferentes**. O **roteador** (ou switch L3, ou firewall) olha o IP de destino de cada pacote, consulta sua **tabela de rotas** e decide o **próximo salto (next hop)**. Ninguém no caminho conhece o trajeto completo; cada equipamento só sabe para onde mandar a seguir. É como pedir informação na rua: cada pessoa aponta a próxima esquina.

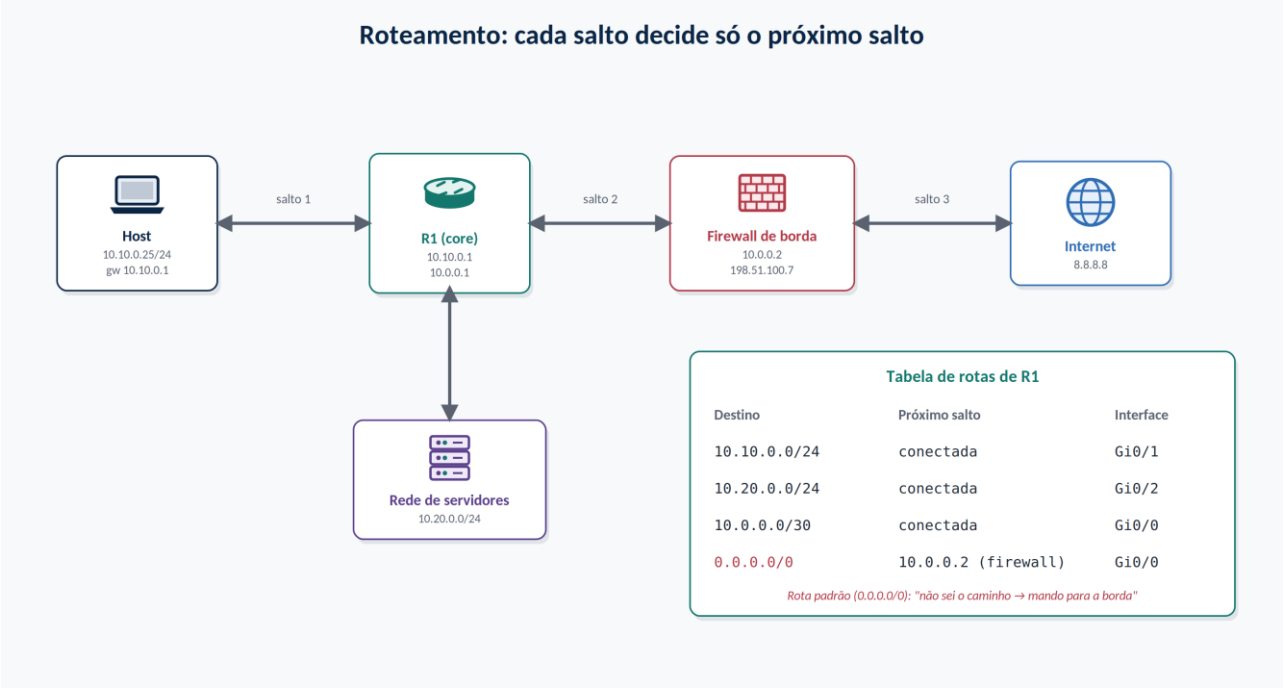


Figura 1.8 — Roteamento salto a salto e a tabela de rotas de um roteador

Conceito	O que é	Exemplo
Router	Equipamento que conecta redes e encaminha pacotes entre elas.	Roteador do core, firewall de borda.
Routing table	Lista de redes de destino e para onde enviar cada uma.	`10.20.0.0/24 → interface Gi0/2`
Default route	Rota usada quando nenhuma outra casa: `0.0.0.0/0`.	Tudo que não é interno vai para o firewall de borda.
Gateway (padrão)	Na estação, o IP do roteador para onde vai tudo que não é da rede local.	`10.10.0.1`
Next hop	O próximo equipamento no caminho.	R1 envia para `10.0.0.2` (firewall).
Longest prefix match	Se várias rotas casam, vence a mais específica.	`10.20.5.0/24` vence `10.20.0.0/16` para `10.20.5.9`.
TTL	Campo IP decrementado a cada salto; em zero, o pacote é descartado.	Base do traceroute (seção 1.13).

Comandos

```
# Windows
route print                  # tabela de rotas
Get-NetRoute -AddressFamily IPv4
tracert 8.8.8.8              # caminho salto a salto (ICMP)
tracert -d 8.8.8.8           # sem resolver nomes (mais rápido)
pathping 8.8.8.8             # traceroute + estatística de perda

# Linux
ip route                     # tabela de rotas
ip route get 8.8.8.8         # qual rota e interface seriam usadas
traceroute 8.8.8.8           # UDP por padrão
traceroute -I 8.8.8.8        # usando ICMP
mtr 8.8.8.8                  # traceroute contínuo
```

```
C:\> route print -4
IPv4 Route Table
===========================================================================
Network Destination        Netmask          Gateway       Interface  Metric
          0.0.0.0          0.0.0.0       10.10.0.1      10.10.0.25     25
        10.10.0.0    255.255.255.0         On-link       10.10.0.25    281
       10.10.0.25  255.255.255.255         On-link       10.10.0.25    281
        127.0.0.0        255.0.0.0         On-link        127.0.0.1    331
```

Como isso aparece no SOC

- **Rota inesperada na estação** (ex.: uma rota para uma rede interna apontando para um IP estranho) pode indicar VPN não autorizada, software de tunelamento ou malware.
- **Split tunneling de VPN:** parte do tráfego vai pela VPN corporativa, parte sai direto pela internet doméstica do usuário. Esse segundo pedaço **não aparece** no proxy nem no firewall da empresa.
- **Rota assimétrica:** o pacote vai por um caminho e volta por outro. Firewalls stateful podem descartar a volta, gerando logs de "sessão inválida" que parecem ataque e são problema de rede.
- **Tráfego que "não passou pelo firewall":** antes de concluir que houve evasão, verifique a topologia. Talvez ele simplesmente não precise passar.

Leitura de SOC	
O que procuro	Por quais equipamentos o tráfego passou (e quais logs existem), rotas incomuns em endpoints, saídas para internet que contornam o caminho oficial.
Pode ser benigno	Rotas criadas por cliente VPN corporativo, por software de virtualização (VirtualBox, Hyper-V, WSL) ou por Docker.
Pode ser suspeito	Rotas apontando para gateways desconhecidos, tunelamento não autorizado (ex.: ferramentas de túnel reverso), estação servindo de roteador entre duas redes.
Próximo passo	Comparar com rotas padrão de imagens corporativas, verificar processos responsáveis no EDR, confirmar com time de redes.
Quando escalo	Endpoint fazendo ponte entre redes segregadas ou túnel não autorizado para fora.

1.8 NAT

O que é e por que existe

NAT (Network Address Translation) é a troca de endereços IP (e às vezes portas) quando o pacote atravessa um equipamento, normalmente o firewall. Existe principalmente porque **não há IPv4 público para todo mundo**: centenas de estações com IPs privados compartilham poucos IPs públicos. Também é usado para publicar serviços internos na internet.

Tipo	O que troca	Uso típico	Exemplo
SNAT (Source NAT)	IP de **origem**	Estações internas acessando a internet.	`10.10.0.25` sai como `198.51.100.7`
DNAT (Destination NAT)	IP de **destino**	Publicar servidor interno (port forwarding).	Internet acessa `198.51.100.10:443` → entregue em `10.50.0.20:443`
PAT / NAT overload / masquerade	IP de origem **e porta**	Muitos hosts compartilhando **um** IP público.	`10.10.0.25:51523` → `198.51.100.7:40001`
NAT estático 1:1	Um IP interno sempre ↔ um IP público	Servidor com IP público dedicado.	`10.50.0.30` ↔ `198.51.100.30`

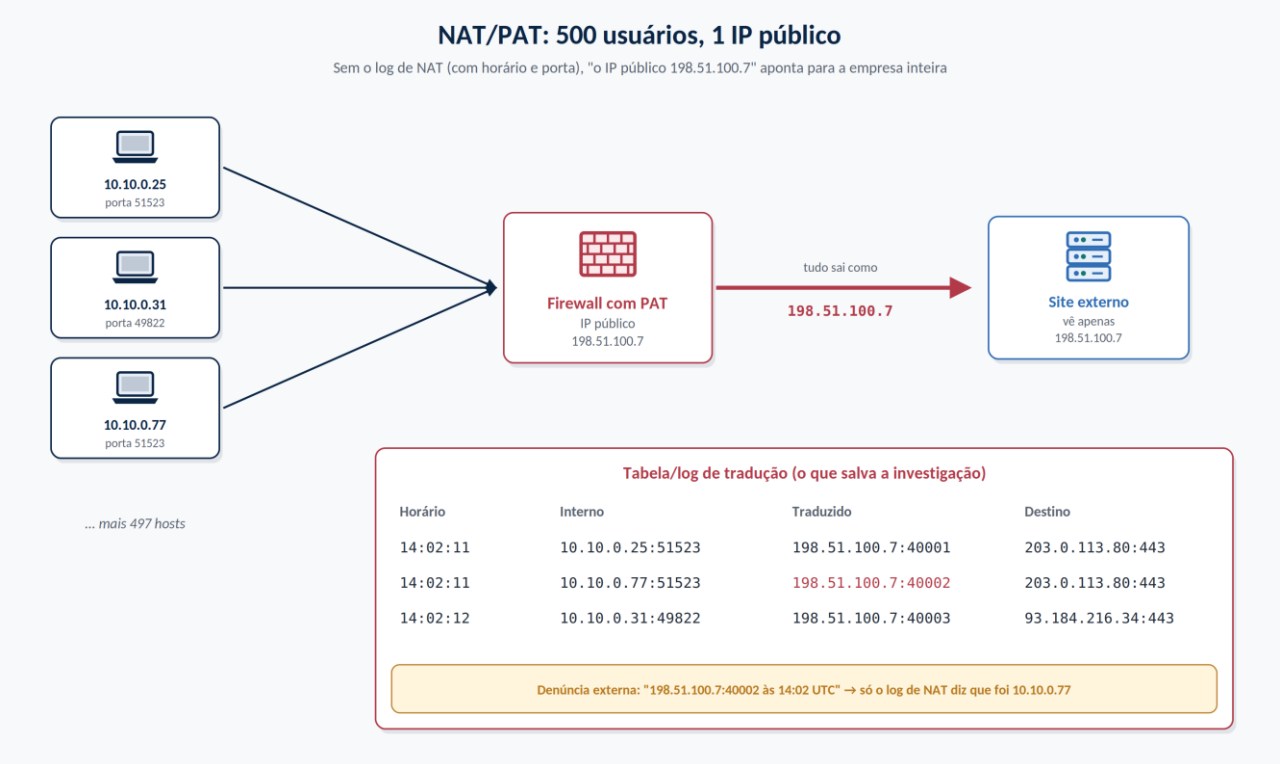


Figura 1.9 — PAT: 500 hosts saindo pelo mesmo IP público e a tabela de tradução

Por que NAT dificulta a investigação

Imagine que um parceiro envia: **"o IP 198.51.100.7 atacou nosso servidor às 14:02"**. Esse é o IP público da empresa inteira. 500 usuários saem por ele. Sem mais informação, você não sabe quem foi.

Para chegar à estação, você precisa de três coisas, e **todas** são obrigatórias:

- **Timestamp preciso, com fuso horário.** "14:02" em UTC ou em horário de Brasília? Três horas de diferença são milhares de traduções diferentes.

- **Porta de origem pública.** É ela que diferencia as 500 conexões simultâneas.
- **Log de NAT do firewall** (ou log de sessão com campos de tradução) com retenção suficiente.

```
# Log de firewall com NAT (formato genérico, estilo FortiGate)
date=2026-09-14 time=14:02:11 tz="-0300" devname="FW-BORDA" action="accept" policyid=12
srcip=10.10.0.77 srcport=51523 srcintf="lan" dstip=203.0.113.80 dstport=443 dstintf="wan1"
transip=198.51.100.7 transport=40002 proto=6 service="HTTPS" sentbyte=1840 rcvdbyte=52311
duration=31

# Leitura: a estação 10.10.0.77 saiu como 198.51.100.7:40002 às 14:02:11 (UTC-3)
# Próximo passo: DHCP diz qual hostname tinha 10.10.0.77 nesse horário; AD/EDR diz o usuário
logado.
```

MOMENTO SOC

Pedido do cliente: "Descubram quem acessou esse site às 14h."

Log de NAT: retenção de 24 horas.

Data do acesso: há 9 dias.

Log do proxy: "em implantação".

Resposta honesta no ticket: "Não é possível atribuir o acesso a um host específico. Motivo: ausência de log de tradução NAT para o período. Recomendação: aumentar retenção dos logs de NAT para pelo menos 90 dias." Isso também é entrega de valor.

Cadeia de atribuição: do IP público até a pessoa

```
IP público + porta + horário
        │  log de NAT (firewall)
        ▼
IP privado da estação
        │  log de DHCP (ou IP fixo na CMDB)
        ▼
MAC + hostname
        │  AD (4624), EDR, proxy autenticado, VPN
        ▼
Usuário logado naquele momento

Cada seta é uma fonte de log diferente. Faltou uma? A cadeia quebra.
```

Leitura de SOC	
O que procuro	Tradução correspondente ao horário e porta informados; se o DNAT publicado expõe serviço indevido; volume de conexões por IP interno.
Pode ser benigno	Muitas sessões do mesmo IP público (é o PAT funcionando); serviços publicados via DNAT documentados.
Pode ser suspeito	DNAT para serviço sensível (RDP, SMB, banco de dados) exposto à internet; host interno com volume de saída muito acima dos demais.
Próximo passo	Seguir a cadeia NAT → DHCP → usuário; documentar cada elo com a evidência.
Quando escalo	Serviço crítico exposto via DNAT sem justificativa ou atribuição de atividade maliciosa a um host interno específico.

1.9 DNS

O que é e por que é tão importante para o SOC

O **DNS** (Domain Name System) traduz nomes (`empresa.com`) em endereços IP e outras informações. Praticamente toda comunicação começa com uma consulta DNS, **inclusive a de malware**: para falar com seu servidor de comando e controle (C2), o malware quase sempre precisa resolver um domínio. Por isso o log de DNS é uma das fontes mais valiosas de um SOC, e uma das mais negligenciadas.

DNS usa principalmente **UDP/53**; usa **TCP/53** para respostas grandes e transferências de zona. Variações cifradas: **DoT** (DNS over TLS, TCP/853) e **DoH** (DNS over HTTPS, TCP/443), que escondem as consultas do resolver corporativo.

Tipos de registro

Registro	Função	Exemplo	Interesse para SOC
A	Nome → IPv4	`empresa.com A 203.0.113.80`	O mais comum. Para onde o host tentou ir.
AAAA	Nome → IPv6	`empresa.com AAAA 2001:db8::80`	Mesmo papel em IPv6.
CNAME	Apelido para outro nome	`www.empresa.com CNAME empresa.cdn.net`	Revela CDN/SaaS por trás. Cadeias longas podem esconder destino final.
MX	Servidor de e-mail do domínio	`empresa.com MX 10 mail.empresa.com`	Investigação de phishing e spoofing.
TXT	Texto livre	`v=spf1 include:_spf.google.com -all`	SPF, DKIM, DMARC, verificações. **Também usado em DNS tunneling** (respostas TXT grandes).
NS	Servidores autoritativos do domínio	`empresa.com NS ns1.empresa.com`	Infraestrutura do domínio; mudanças podem indicar sequestro.
PTR	IP → nome (DNS reverso)	`80.113.0.203.in-addr.arpa PTR web01.empresa.com`	Enriquecimento: reverso de IP externo pode revelar provedor ou função.
SOA	Autoridade e parâmetros da zona	serial, refresh, TTL mínimo	Raramente usado pelo N1; útil para entender a zona.
SRV	Localiza serviços	`_ldap._tcp.dc._msdcs.corp.local`	Estações acham controladores de domínio assim (Módulo 8).

Como a resolução funciona

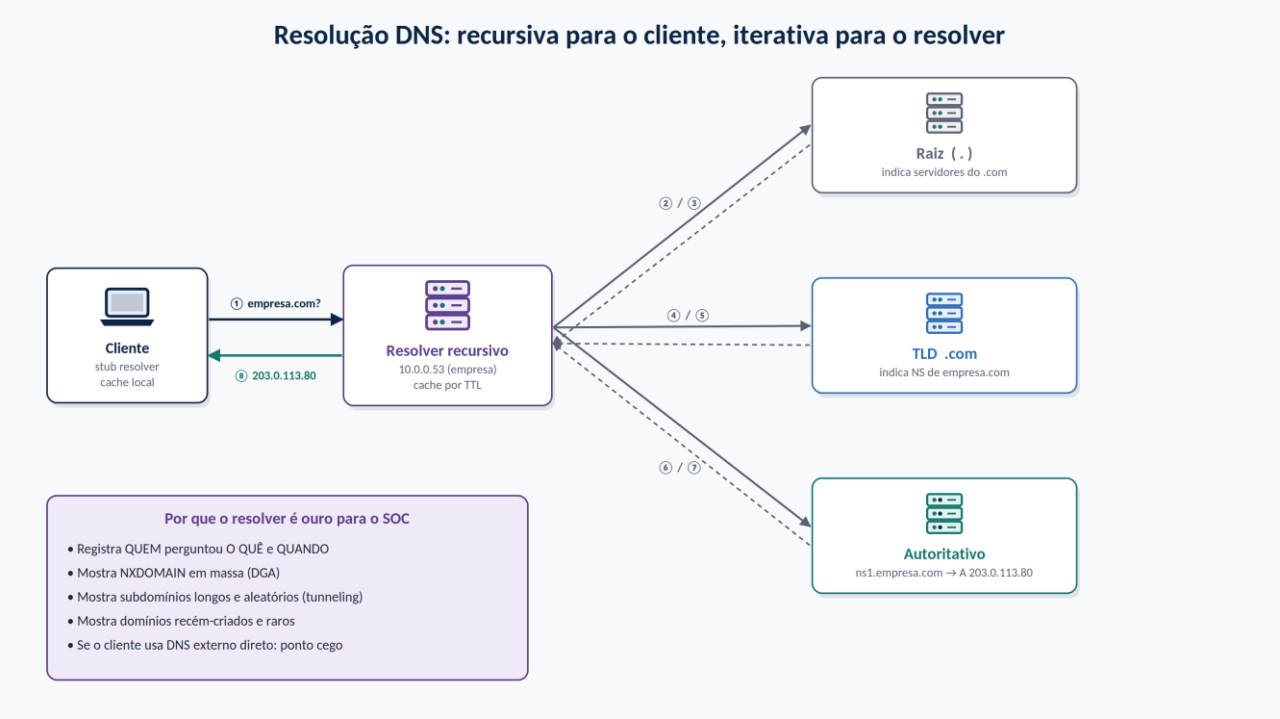


Figura 1.10 — Resolução DNS: cliente → resolver recursivo → raiz → TLD → autoritativo

- **Stub resolver:** o componente do sistema operacional que faz a pergunta. Pede uma resposta **recursiva**: "me traga o IP final".
- **Resolver recursivo:** normalmente o servidor DNS da empresa (muitas vezes o próprio controlador de domínio) ou um público (`8.8.8.8`, `1.1.1.1`). Faz o trabalho de perguntar à hierarquia.
- **Raiz → TLD → autoritativo:** o resolver pergunta à raiz quem cuida de `.com`, ao `.com` quem cuida de `empresa.com`, e ao **servidor autoritativo** qual é o registro. Essas são consultas **iterativas**.
- **Cache e TTL:** cada resposta tem um **TTL** (tempo de vida) em segundos. Enquanto não expira, o resolver e o cliente respondem do cache. TTL muito baixo (ex.: 60s) com IPs mudando constantemente é um sinal de **fast flux**.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Consequência prática do cache: **nem toda conexão gera consulta DNS no log**. Se o host consultou o domínio às 09:00 com TTL de 1 hora, a conexão das 09:40 não gera nova consulta. Ausência de DNS no log não prova que não houve acesso.
>
> E o inverso: **consulta DNS não prova conexão**. Navegadores fazem pré-resolução (prefetch) de links da página. O host pode ter resolvido o domínio malicioso sem nunca ter conectado nele. Confirme no firewall, proxy ou EDR.

Abusos de DNS (visão defensiva)

Técnica	Como funciona	Sinais nos logs	Falsos positivos comuns
DNS tunneling	Dados codificados em subdomínios (consulta) e em respostas TXT/NULL; o atacante controla o autoritativo e recebe tudo.	Subdomínios longos e aleatórios (`a9f3k2...x7.dados.evil.com`); volume alto de consultas para um único domínio; muitas consultas TXT; alta entropia.	Antivírus e EDRs que consultam reputação via DNS; CDNs; serviços de telemetria com hashes no nome.

Técnica	Como funciona	Sinais nos logs	Falsos positivos comuns
DGA (Domain Generation Algorithm)	Malware gera centenas de domínios pseudoaleatórios por dia; o atacante registra só alguns.	Muitas respostas **NXDOMAIN** de um único host; nomes sem sentido (`xkqpzlw.biz`).	Navegador Chrome testando NXDOMAIN de propósito (nomes aleatórios curtos na inicialização); erros de digitação.
Fast flux	Um domínio aponta para dezenas de IPs que mudam rapidamente (botnet).	TTL muito baixo; muitos registros A diferentes ao longo do dia; IPs em ASNs residenciais.	CDNs e balanceamento global legítimo também têm TTL baixo e muitos IPs, mas em ASNs conhecidos.
Domínios recém-criados	Phishing e C2 usam domínios registrados há horas ou dias.	Idade do domínio (WHOIS) muito baixa; categoria "newly registered" no proxy/DNS.	Campanhas legítimas de marketing, novos serviços SaaS.
Typosquatting / look-alike	Domínios parecidos com o legítimo.	`micros0ft-login.com`, `empresa-seguranca.com`, `rnicrosoft.com`.	Domínios defensivos registrados pela própria empresa.
DoH não autorizado	Consultas DNS cifradas via HTTPS contornam o resolver corporativo.	Conexões 443 para resolvers DoH conhecidos; host sem consultas DNS no log mas navegando.	Navegadores com DoH ativado por padrão em alguns cenários.

Logs relacionados

```
# Windows DNS Server (debug log, simplificado)
14/09/2026 10:15:02 0A3C PACKET UDP Rcv 10.10.0.77  4f2a   Q [0001 D NOERROR] A
(7)empresa(3)com(0)

# Sysmon Event ID 22 (DNS query, na estação — mostra o PROCESSO)
EventID: 22  Image: C:\Users\jsilva\AppData\Roaming\upd\svc.exe
QueryName: k3j9x0qz7a.cdn-update-check.top  QueryStatus: 0  QueryResults: ::ffff:185.0.2.44;

# Zeek dns.log (campos principais)
ts=1757855702.1 id.orig_h=10.10.0.77 query=a1b2c3d4e5f6a7b8c9d0e1f2a3b4c5d6.t.evil.example
qtype_name=TXT rcode_name=NOERROR

# Resolver/firewall DNS (genérico) — padrão de DGA
10:20:01 client=10.10.0.91 query=qwzpxkt.info  rcode=NXDOMAIN
10:20:01 client=10.10.0.91 query=lmvhrbs.net   rcode=NXDOMAIN
10:20:02 client=10.10.0.91 query=zpkqwnd.biz   rcode=NXDOMAIN
... (412 respostas NXDOMAIN em 3 minutos)
```

Comandos

```
# Windows
nslookup empresa.com                # consulta usando o DNS configurado
nslookup empresa.com 8.8.8.8        # forçando um resolver
nslookup -type=mx empresa.com       # registro MX
nslookup -type=txt empresa.com      # TXT (SPF etc.)
Resolve-DnsName empresa.com -Type A  # PowerShell
ipconfig /displaydns                # cache DNS local (útil em investigação!)
ipconfig /flushdns                  # limpa cache (CUIDADO: apaga evidência)
```

```
# Linux
dig empresa.com                     # consulta completa com TTL
dig +short empresa.com              # só o resultado
dig empresa.com MX
dig -x 203.0.113.80                 # DNS reverso (PTR)
dig @1.1.1.1 empresa.com            # resolver específico
dig +trace empresa.com              # mostra raiz → TLD → autoritativo
resolvectl query empresa.com        # sistemas com systemd-resolved

# WHOIS (idade e registrante do domínio)
whois exemplo-suspeito.com
```

> **NA VIDA REAL**
>
> Analista novo, querendo ajudar: "Rodei `ipconfig /flushdns` na máquina do usuário para limpar o domínio malicioso."
>
> DFIR, uma semana depois: "Precisávamos do cache DNS."
>
> Coletar antes, agir depois. Sempre.

Leitura de SOC	
O que procuro	Qual host (e qual processo, se houver Sysmon/EDR) consultou o domínio; idade e reputação do domínio; volume, entropia, NXDOMAIN, tipo de registro; se a consulta virou conexão.
Pode ser benigno	Domínios de SaaS conhecidos, CDNs, telemetria de fornecedores, consultas de reputação de antivírus, prefetch de navegador.
Pode ser suspeito	Processo incomum (fora de navegador) resolvendo domínio recém-criado; NXDOMAIN em massa; subdomínios longos e aleatórios; TXT em volume; resolução de domínio presente em inteligência de ameaças.
Próximo passo	Enriquecer o domínio (WHOIS, reputação, passive DNS), buscar outros hosts que consultaram o mesmo domínio, confirmar conexão no firewall/proxy/EDR.
Quando escalo	Domínio malicioso confirmado com conexão estabelecida; padrão de DGA ou tunneling a partir de um endpoint; múltiplos hosts consultando o mesmo domínio suspeito.

1.10 DHCP

O **DHCP** (Dynamic Host Configuration Protocol) entrega automaticamente a configuração de rede aos dispositivos: **IP, máscara, gateway, servidores DNS** e o tempo de validade dessa concessão (**lease**). Usa **UDP 67** (servidor) e **UDP 68** (cliente).

DORA

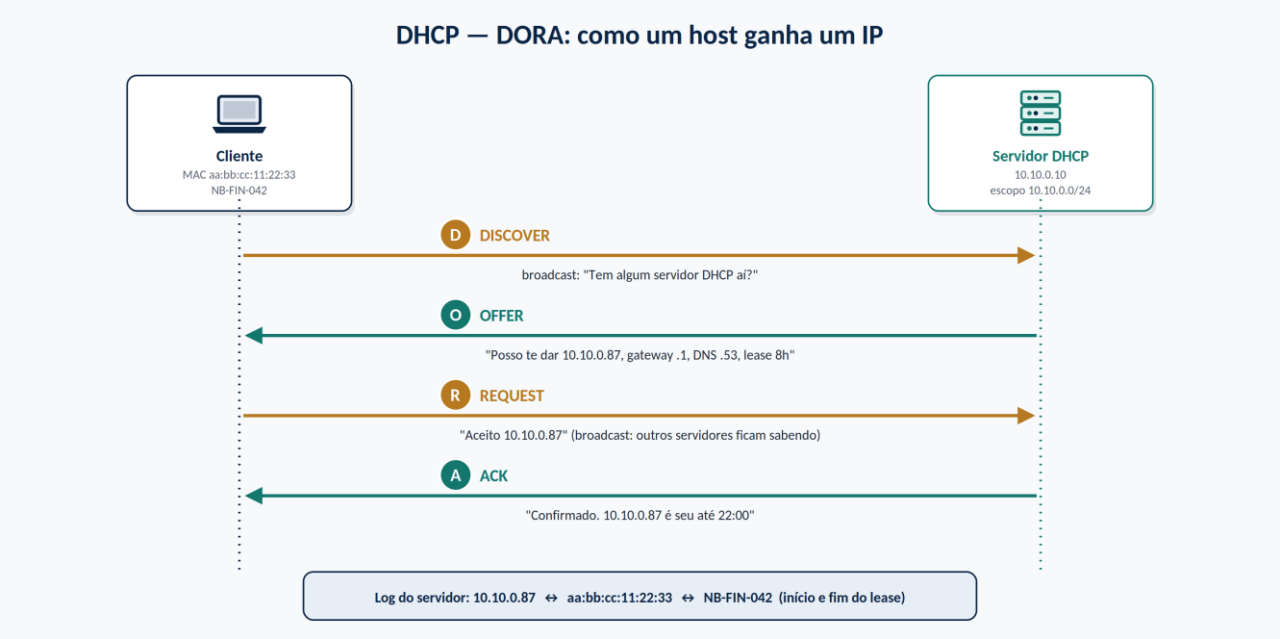


Figura 1.11 — As quatro mensagens do DHCP: Discover, Offer, Request, Acknowledge

Etapa	Quem envia	Como	Conteúdo
Discover	Cliente	Broadcast (origem 0.0.0.0, destino 255.255.255.255)	"Preciso de um IP." Inclui o MAC e, muitas vezes, o hostname.
Offer	Servidor	Unicast ou broadcast	Proposta: IP, máscara, gateway, DNS, lease.
Request	Cliente	Broadcast	"Aceito a oferta deste servidor." Outros servidores retiram suas ofertas.
Acknowledge	Servidor	Unicast ou broadcast	Confirmação. O IP é do cliente até o fim do lease.

O cliente tenta **renovar** o lease na metade do tempo (T1) diretamente com o servidor. Se nenhum servidor responder, o Windows recorre ao **APIPA** (`169.254.x.x`).

Por que DHCP é essencial em investigação

Em redes com DHCP, **o mesmo IP pertence a máquinas diferentes ao longo do tempo**. O alerta diz `10.10.0.87` às 02:14. Quem era `10.10.0.87` às 02:14? Não necessariamente quem é agora. O log de DHCP é a ponte:

```
IP  ⟶  MAC  ⟶  hostname  (válido entre início e fim do lease)
```

```
# Windows DHCP Server (DhcpSrvLog-*.log, formato CSV)
ID,Date,Time,Description,IP Address,Host Name,MAC Address,...
10,09/14/26,01:58:40,Assign,10.10.0.87,NB-FIN-042.corp.local,AABBCC112233,...
11,09/14/26,09:58:41,Renew,10.10.0.87,NB-FIN-042.corp.local,AABBCC112233,...
18,09/14/26,18:30:12,Expired,10.10.0.87,,AABBCC112233,...
10,09/14/26,19:02:05,Assign,10.10.0.87,VISITANTE-PC,F0DEF1A2B3C4,...

# Leitura: às 02:14, 10.10.0.87 era NB-FIN-042 (MAC AA:BB:CC:11:22:33).
# Às 19:10 do mesmo dia, o mesmo IP era VISITANTE-PC. Horário importa.

# ISC dhcpd (Linux, syslog)
```

```
Sep 14 01:58:40 dhcp01 dhcpd[812]: DHCPACK on 10.10.0.87 to aa:bb:cc:11:22:33 (NB-FIN-042) via
eth0
```

Abusos e problemas relacionados

Situação	Ideia	Sinal
Rogue DHCP	Servidor não autorizado entrega gateway/DNS do atacante, viabilizando MitM.	Clientes com gateway ou DNS inesperado; alertas de DHCP snooping; Offers vindos de IP desconhecido.
DHCP starvation	Esgotar o pool com pedidos de MACs falsos.	Pool esgotado; centenas de leases para MACs aleatórios numa porta.
Dispositivo desconhecido	Hostname estranho ou genérico pedindo IP.	`DESKTOP-8K2J3LQ`, `kali`, `raspberrypi` na rede corporativa.
Pool esgotado (operacional)	Mais dispositivos que IPs no escopo.	Usuários com APIPA; reclamações de "sem internet". Problema de NOC/infra, mas o SOC vê o efeito.

> **MOMENTO SOC**
>
> Hostname no DHCP: `kali`.
>
> Analista: "Pentester autorizado?"
>
> Gestão: "Não temos pentest agendado."
>
> Time de TI: "Ah, é o estagiário estudando para certificação."
>
> Pode ser benigno. Mesmo assim, uma máquina com ferramentas ofensivas não gerenciada na rede corporativa é um achado para registrar e reportar conforme política, não para ignorar.

Comandos

```
# Windows
ipconfig /all            # servidor DHCP, lease obtido e expiração
ipconfig /release        # libera o IP (cuidado: derruba a conexão)
ipconfig /renew          # pede novo lease
Get-DhcpServerv4Lease -ScopeId 10.10.0.0 -ComputerName dhcp01   # no servidor (módulo
DhcpServer)

# Linux
journalctl -u NetworkManager | grep -i dhcp   # leases recebidos
cat /var/lib/dhcp/dhclient.leases            # cliente dhclient
cat /var/lib/dhcp/dhcpd.leases               # servidor ISC (no servidor)
```

Leitura de SOC	
O que procuro	Qual MAC/hostname tinha o IP no horário exato do evento; hostnames fora do padrão corporativo; servidores DHCP não autorizados.
Pode ser benigno	Renovações normais; dispositivos de convidados na VLAN de convidados; novos notebooks recém-entregues com nome padrão de fábrica.

Leitura de SOC	
Pode ser suspeito	Hostname de distribuição ofensiva ou genérico em VLAN corporativa; MAC de fabricante incomum; Offers de servidor desconhecido; explosão de leases.
Próximo passo	Registrar o mapeamento IP → MAC → hostname com o horário no ticket; localizar o ativo na CMDB/EDR; verificar porta de switch/NAC.
Quando escalo	Rogue DHCP, dispositivo não gerenciado envolvido em atividade suspeita ou impossibilidade de atribuir IP a um host em incidente ativo (lacuna de visibilidade).

Fechamento da Parte 1

Ferramentas desta parte

Ferramenta	Para que serve no SOC	Gratuita?
`ipconfig` / `ip`	Ver configuração de rede do host analisado.	Nativo
`arp` / `ip neigh` / `Get-NetNeighbor`	Ver cache ARP (IP ↔ MAC).	Nativo
`route` / `ip route` / `tracert` / `traceroute`	Entender caminhos e rotas.	Nativo
`nslookup` / `dig` / `Resolve-DnsName`	Consultar DNS, registros e reverso.	Nativo / pacote
`whois`	Idade e registrante de domínios, dono de blocos IP.	Sim
`ipcalc` / Python `ipaddress`	Cálculo de sub-redes.	Sim
Consulta de OUI (ex.: bases públicas de fabricantes MAC)	Descobrir fabricante pelo MAC.	Sim
Zeek	Gera logs ricos de rede (conn, dns, dhcp, ssl, http).	Sim
Suricata	IDS/IPS com assinaturas; detecta ARP spoofing, DNS suspeito etc.	Sim
Wireshark	Ver pacotes ARP, DHCP, DNS na prática (Parte 2).	Sim

Erros comuns

Erro	Por que é um problema	Como evitar
Achar que IP = pessoa	Leva a acusar o usuário errado.	Seguir a cadeia NAT → DHCP → logon, com horário.
Ignorar o fuso horário	O mapeamento NAT/DHCP dá o host errado.	Normalizar tudo em UTC no ticket e indicar o fuso original.
Achar que `172.x.x.x` é sempre privado	Só 172.16 a 172.31 é privado.	Decorar `172.16.0.0/12` e entender o porquê.
Achar que consulta DNS = conexão	Prefetch e cache distorcem.	Confirmar em firewall/proxy/EDR.
Concluir que "não passou pelo firewall" é evasão	Talvez estivessem na mesma VLAN.	Conhecer a topologia antes de concluir.
Executar `flushdns`, `release` ou reiniciar o host	Destrói evidência volátil.	Coletar primeiro; agir só conforme Runbook.
Esperar MAC em log de firewall de borda	MAC muda a cada salto.	MAC só existe na LAN: switch, DHCP, NAC, EDR.
Decorar portas sem entender camadas	Trava diante do primeiro protocolo novo.	Sempre perguntar: que camada, que equipamento vê, que log existe.

Falsos positivos comuns

Alerta	Causa benigna frequente	Como confirmar
"Possível ARP spoofing"	Failover de gateway (VRRP/HSRP), troca de equipamento.	Mudança aprovada; MAC pertence a equipamento de rede do mesmo fabricante.
"Muitas NXDOMAIN"	Software mal configurado consultando nome inexistente em loop; Chrome testando hijack de DNS.	Nomes repetitivos ou padrão conhecido; processo legítimo no EDR.
"Subdomínio longo / alta entropia"	Antivírus/EDR consultando reputação por DNS; CDNs; serviços de nuvem.	Domínio do fornecedor de segurança ou nuvem conhecido.
"Domínio recém-registrado"	Novo SaaS contratado, campanha de marketing.	Confirmar com área de negócio; reputação limpa; certificados legítimos.
"Dispositivo desconhecido no DHCP"	Notebook novo com nome de fábrica; celular de funcionário em rede de convidados.	Consultar CMDB/entrega de equipamentos; VLAN correta.
"Comunicação com IP privado estranho"	Rede do Docker (`172.17.0.0/16`), WSL, Hyper-V.	Processo responsável no EDR; faixa típica de virtualização.

Exercícios

Faça antes de olhar as respostas, que estão no final da Parte 1.

1. Para cada IP, diga se é privado, público ou especial (e qual): `10.255.3.1`, `172.15.9.9`, `172.20.0.5`, `192.168.300.1`, `169.254.10.20`, `100.72.1.9`, `127.0.0.53`, `8.8.4.4`.
2. Calcule rede, broadcast, faixa de hosts e quantidade de hosts para `192.168.10.77/26`.
3. `10.1.1.200/25` e `10.1.1.100/25` estão na mesma rede? E `10.1.1.200/24` e `10.1.1.100/24`?
4. Em que camada OSI atua cada item: (a) switch, (b) roteador, (c) WAF, (d) ARP spoofing, (e) SYN flood, (f) SQL Injection, (g) cabo cortado.
5. Descreva, em ordem, os protocolos envolvidos quando uma estação acessa `https://portal.empresa.com` pela primeira vez no dia.
6. Um alerta mostra `src=198.51.100.7` (IP público da sua empresa) atacando um site externo às 14:02. Liste exatamente o que você precisa para descobrir a estação de origem e onde buscar cada item.
7. O alerta diz que `10.10.0.87` acessou um domínio malicioso às 02:14. Agora, às 10h, `10.10.0.87` é a máquina do diretor financeiro. Ele é o responsável? Justifique e diga o próximo passo.
8. Um host gerou 600 consultas com resposta NXDOMAIN em 5 minutos, para nomes como `pqzkxw.top` e `mnvbtr.info`. O que isso sugere? Cite uma explicação benigna possível e o próximo passo.
9. Você vê no log de arpwatch que o IP do gateway `192.168.1.1` passou a ter o MAC de um notebook de usuário. O que isso sugere e qual a urgência?
10. Por que a falta de log de firewall para uma comunicação entre duas estações não significa que o tráfego não existiu?
11. Converta `/27` em máscara decimal e diga quantos hosts úteis possui.
12. Explique por que uma consulta DNS para um domínio malicioso, sozinha, não prova que a estação foi comprometida.

Laboratório

LABORATÓRIO — Lab 1.1 — Conhecendo a sua própria rede

Objetivo: aplicar endereçamento, ARP, rotas e DNS no seu próprio computador. Use apenas equipamentos e redes **seus**.

Duração: 45 a 60 minutos.

- Execute `ipconfig /all` (Windows) ou `ip a` e `ip route` (Linux). Anote IP, máscara/CIDR, gateway, DNS e servidor DHCP.
- Calcule à mão a rede, o broadcast e a quantidade de hosts da sua sub-rede. Confira com Python `ipaddress`.
- Rode `arp -a` (ou `ip neigh`). Encontre o MAC do seu gateway. Pesquise o fabricante pelo OUI (3 primeiros bytes).
- Rode `route print` (ou `ip route`). Identifique a rota padrão e interprete cada linha.
- Rode `tracert -d 8.8.8.8` (ou `traceroute -I 8.8.8.8`). Quantos saltos? Qual é o primeiro? Por quê?
- Rode `ipconfig /displaydns`. Que domínios aparecem? Algum você não reconhece? Pesquise (sem acessar) com `nslookup` e `whois`.
- Documente tudo em `labs/lab-1.1.md` no seu repositório.

LABORATÓRIO — Lab 1.2 — DNS na prática

- Use `dig` (ou `Resolve-DnsName`) para obter os registros A, AAAA, MX, TXT e NS de um domínio grande e conhecido.
- Rode `dig +trace` para ver a cadeia raiz → TLD → autoritativo. Identifique cada etapa.
- Compare o TTL de duas consultas seguidas ao seu resolver: ele diminui? Por quê?
- Faça `dig -x` em dois IPs públicos de resolvers conhecidos e observe o PTR.
- No registro TXT, encontre o SPF do domínio e explique, em uma frase, o que ele declara (será aprofundado no Módulo 9).
- Documente em `labs/lab-1.2.md`.

LABORATÓRIO — Lab 1.3 — Exercício de atribuição (papel e caneta)

Usando apenas os logs sintéticos abaixo, descubra **qual hostname e qual usuário** estavam por trás do acesso denunciado.

Denúncia: `198.51.100.7:40002` acessou `203.0.113.80:443` em 14/09/2026 17:02:11 **UTC**.

Log NAT (horário local UTC-3): `14:02:11 srcip=10.10.0.77 srcport=51523 transip=198.51.100.7 transport=40002 dstip=203.0.113.80 dstport=443`

Log DHCP: `09/14/26 07:51:03 Assign 10.10.0.77 NB-RH-007 001122AABB07` e `09/14/26 16:40:00 Expired 10.10.0.77`

Windows 4624 em NB-RH-007: `14/09/2026 07:55:10 TargetUserName=ana.lima LogonType=2`

Escreva a conclusão como se fosse um ticket, citando cada evidência e a conversão de fuso.

Perguntas de entrevista

P: Explique o modelo OSI.

Resposta fraca	Resposta boa
"São 7 camadas: física, enlace, rede, transporte, sessão, apresentação e aplicação."	É um modelo de referência que divide a comunicação em 7 camadas, cada uma com uma função: física transmite bits, enlace entrega quadros na rede local com MAC, rede endereça e roteia com IP, transporte entrega entre processos com portas via TCP ou UDP, e as camadas superiores cuidam de sessão, formato/cifra e do protocolo da aplicação. No SOC eu uso para saber que equipamento enxerga cada tipo de atividade: um firewall tradicional vê camadas 3 e 4, um WAF vê camada 7.

O que está sendo avaliado: Se o candidato entende a função das camadas e consegue aplicar o modelo, não só recitar.

P: Qual a diferença entre camada 2 e camada 3?

Resposta fraca	Resposta boa
"Uma é switch e outra é roteador."	Camada 2 é a comunicação dentro da mesma rede local, usando endereços MAC e quadros; o switch atua aqui. Camada 3 é a comunicação entre redes diferentes, usando IP e pacotes; o roteador decide o próximo salto. O MAC muda a cada salto, o IP de destino normalmente não, exceto com NAT.

O que está sendo avaliado: Compreensão de escopo local versus roteado.

P: O que acontece quando você digita um site no navegador?

Resposta fraca	Resposta boa
"O navegador abre o site."	Verifica cache, resolve o nome via DNS, decide se o destino é local ou vai ao gateway, usa ARP para achar o MAC do gateway, faz o handshake TCP na porta 443, negocia TLS com SNI e certificado, passa por NAT no firewall, envia a requisição HTTP, recebe a resposta e o navegador renderiza. No SOC, cada etapa deixa log em uma fonte diferente: DNS, firewall, proxy, EDR.

O que está sendo avaliado: Visão de ponta a ponta e ligação com fontes de log.

P: O que é ARP?

Resposta fraca	Resposta boa
"É um protocolo de rede."	É o protocolo que descobre o MAC correspondente a um IP na rede local, por broadcast "quem tem tal IP" e resposta unicast. Não tem autenticação, o que permite ARP spoofing. Sinais: mesmo MAC respondendo por vários IPs, mudança do MAC do gateway, alertas de DAI.

O que está sendo avaliado: Funcionamento e impacto de segurança.

P: O que é NAT e por que atrapalha investigações?

Resposta fraca	Resposta boa
"NAT esconde o IP."	NAT traduz endereços na passagem pelo firewall; com PAT, centenas de hosts saem por um único IP público, diferenciados pela porta. Para atribuir uma conexão a um host interno preciso do horário exato com fuso, da porta de origem pública e do log de tradução. Depois sigo para DHCP e logon para chegar ao usuário.

O que está sendo avaliado: Raciocínio de atribuição e dependência de logs.

P: O que é DNS e por que é importante para o SOC?

Resposta fraca	Resposta boa
"Transforma nome em IP."	Traduz nomes em IPs e outros registros. É importante porque quase toda comunicação, inclusive de malware, começa com uma consulta. Logs de DNS revelam domínios recém-criados, DGA por NXDOMAIN em massa, tunneling por subdomínios longos e respostas TXT, e permitem achar outros hosts que consultaram o mesmo domínio. Mas consulta não prova conexão.

O que está sendo avaliado: Valor investigativo e limites da fonte.

P: Para que serve o log de DHCP numa investigação?

Resposta fraca	Resposta boa
"Para ver os IPs."	Para saber qual máquina tinha determinado IP num horário específico, já que IPs dinâmicos mudam de dono. Ele liga IP, MAC e hostname com início e fim do lease. Sem ele, posso atribuir um alerta à máquina errada.

O que está sendo avaliado: Noção de temporalidade da evidência.

P: O IP 172.32.10.5 é privado?

Resposta fraca	Resposta boa
"Sim, começa com 172."	Não. A faixa privada é 172.16.0.0/12, de 172.16.0.0 a 172.31.255.255. 172.32.10.5 é público e precisa ser enriquecido como externo.

O que está sendo avaliado: Precisão técnica; pegadinha clássica.

P: Quantos hosts cabem numa /26?

Resposta fraca	Resposta boa
"64."	64 endereços, 62 hosts utilizáveis, descontando endereço de rede e broadcast. A conta é 2 elevado a 32 menos 26, menos 2.

O que está sendo avaliado: Domínio mínimo de subnetting.

P: Por que VLANs importam numa investigação?

Resposta fraca	Resposta boa
"Porque separam a rede."	Porque definem quem pode falar com quem e onde existe log. Tráfego entre VLANs passa pelo firewall ou roteador e pode ser registrado; tráfego dentro da mesma VLAN passa só pelo switch e geralmente só aparece em EDR ou NetFlow. Também ajudam a medir o alcance de um host comprometido.

O que está sendo avaliado: Ligação entre arquitetura e visibilidade.

Checklist de domínio — Parte 1

- ☐ Explico as 7 camadas do OSI com função, PDU, protocolos, dispositivos, ataques e fontes de log.
- ☐ Comparo OSI e TCP/IP e sei quando uso cada um.
- ☐ Descrevo o encapsulamento e sei que o MAC muda a cada salto.
- ☐ Descrevo os passos de um acesso HTTPS e qual log registra cada um.
- ☐ Reconheço IP privado, público, loopback, APIPA, CGNAT, multicast e documentação.
- ☐ Calculo rede, broadcast, faixa e quantidade de hosts para qualquer CIDR de /22 a /30.
- ☐ Explico ARP, ARP spoofing e seus sinais defensivos.
- ☐ Explico switch, tabela MAC, VLAN, access, trunk e 802.1Q, e por que VLAN importa na investigação.
- ☐ Leio uma tabela de rotas e sei o que é rota padrão e next hop.
- ☐ Explico SNAT, DNAT e PAT e sigo a cadeia NAT → DHCP → usuário.
- ☐ Explico os registros DNS, a resolução recursiva/iterativa, cache e TTL, e os abusos de DNS.
- ☐ Explico o DORA e uso o log de DHCP para mapear IP → MAC → hostname num horário.
- ☐ Concluí os Labs 1.1, 1.2 e 1.3.

Resumo da Parte 1

- O **OSI** é um mapa de raciocínio: cada camada tem dispositivos, ataques e logs próprios. O **TCP/IP** é a implementação real.
- **Encapsulamento:** dados → segmento → pacote → quadro → bits. O MAC muda a cada salto; o IP, só com NAT.
- Um simples acesso HTTPS envolve **DNS, rota, ARP, TCP, NAT, TLS e HTTP**, e cada etapa deixa rastro numa fonte diferente.
- Reconhecer **IP privado x público x especial** e calcular **CIDR** é rotina do N1.
- **ARP** não tem autenticação; mudança de MAC do gateway é sinal de MitM.
- **VLAN** define quem fala com quem e **onde existe log**.
- **NAT** esconde centenas de hosts atrás de um IP; sem horário, porta e log de tradução, não há atribuição.
- **DNS** é uma das melhores fontes de detecção, mas consulta não prova conexão e cache esconde consultas.
- **DHCP** liga IP, MAC e hostname no tempo. IP não é pessoa.

Respostas comentadas dos exercícios

Exercício 1. `10.255.3.1` privado (10/8). `172.15.9.9` **público** (fora de 172.16–172.31). `172.20.0.5` privado (172.16/12). `192.168.300.1` **inválido**: octeto acima de 255; em log, indica erro de parser ou de digitação. `169.254.10.20` APIPA (falha de DHCP). `100.72.1.9` CGNAT (100.64/10), comum em provedores; não é IP público do usuário. `127.0.0.53` loopback (é o stub resolver do systemd-resolved no Linux). `8.8.4.4` público (resolver do Google).

Exercício 2. /26 → máscara 255.255.255.192 → bloco 256 − 192 = 64 → blocos .0, .64, .128, .192. 77 está no bloco .64. Rede `192.168.10.64`, hosts `.65` a `.126`, broadcast `.127`, 62 hosts úteis.

Exercício 3. Com /25, os blocos são .0–.127 e .128–.255: `.200` e `.100` estão em **redes diferentes** e precisam de roteador. Com /24, ambos estão em `10.1.1.0/24`: **mesma rede**. Moral: a máscara faz parte da resposta.

Exercício 4. (a) Switch: camada 2 (switches L3 também roteiam). (b) Roteador: camada 3. (c) WAF: camada 7. (d) ARP spoofing: camada 2 (envolve mapeamento com camada 3). (e) SYN flood: camada 4. (f) SQL Injection: camada 7. (g) Cabo cortado: camada 1.

Exercício 5. DNS (UDP/53) para resolver `portal.empresa.com` → decisão de rota (local ou gateway) → ARP para o MAC do gateway (se não estiver em cache) → TCP handshake para a porta 443 → NAT no firewall, se o portal estiver na internet → TLS (ClientHello com SNI, certificado) → HTTP dentro do TLS → resposta pelo caminho inverso. Se o portal for interno, provavelmente não há NAT e o DNS interno responde com IP privado.

Exercício 6. Precisa de: (1) **horário exato com fuso** da denúncia; (2) **porta de origem pública** usada; (3) **IP de destino** para filtrar. Com isso, consulta o **log de NAT/sessão do firewall** para obter o IP privado e a porta interna. Depois, o **log de DHCP** (ou CMDB, se IP fixo) para obter MAC e hostname naquele horário. Por fim, **eventos de logon (4624), EDR, proxy autenticado ou VPN** para o usuário. Se a denúncia não tiver porta, documente que a atribuição pode ser ambígua e liste todos os candidatos no período.

Exercício 7. Não necessariamente. O IP é dinâmico; quem o tinha às 02:14 pode ser outra máquina. Próximo passo: consultar o log de DHCP para o horário 02:14 (convertendo o fuso, se necessário), identificar MAC e hostname, e só então verificar o usuário logado naquele host. Acusar o diretor com base no IP atual seria um erro grave.

Exercício 8. Sugere **DGA**: malware gerando domínios pseudoaleatórios até encontrar um registrado. Explicação benigna possível: software mal configurado ou o teste do Chrome que consulta nomes aleatórios (mas esse gera poucas consultas, não 600). Próximo passo: identificar o processo responsável (Sysmon 22/EDR), verificar se algum desses domínios **resolveu** (NOERROR) e se houve conexão ao IP resultante, buscar o mesmo padrão em outros hosts. Com processo desconhecido, tende a escalonamento.

Exercício 9. Sugere **ARP spoofing** com o notebook tentando se passar pelo gateway (MitM). Urgência **alta**: indica atacante (ou ferramenta) ativo dentro da rede local, interceptando tráfego de outras estações. Exceção a verificar rapidamente: não é failover de gateway, porque o MAC pertence a um notebook e não a um equipamento de rede. Escalar imediatamente com as evidências (log, MAC, OUI, porta de switch se disponível).

Exercício 10. Porque, se as duas estações estão na **mesma VLAN/sub-rede**, o tráfego vai direto pelo switch, sem passar pelo firewall. Nesse caso, apenas EDR, Sysmon, NetFlow interno ou um sensor de rede na LAN registrariam a comunicação. Ausência de log é ausência de visibilidade, não ausência de evento.

Exercício 11. /27 = 255.255.255.224. São 2^5 = 32 endereços e 30 hosts úteis.

Exercício 12. Porque a consulta pode ter sido feita por **prefetch** do navegador, por um link exibido numa página, por uma ferramenta de segurança verificando reputação ou pode ter sido bloqueada depois (sinkhole, proxy, firewall). Comprometimento exige mais evidência: conexão estabelecida e com volume, processo suspeito, download, persistência ou outros sinais no endpoint. A consulta é um **ponto de partida**, não uma conclusão.

Lab 1.3 — resolução. 17:02:11 UTC = 14:02:11 em UTC-3. O log de NAT mostra que `198.51.100.7:40002` correspondia a `10.10.0.77:51523` nesse horário. O DHCP mostra que `10.10.0.77` foi atribuído a `NB-RH-007` (MAC 00:11:22:AA:BB:07) às 07:51 e só expirou às 16:40, portanto era dele às 14:02. O 4624 mostra logon interativo (tipo 2) de `ana.lima` às 07:55 em NB-RH-007. Conclusão: o acesso partiu de NB-RH-007, com sessão de ana.lima. **Ressalva** a documentar: é preciso confirmar que não houve logoff ou troca de usuário entre 07:55 e 14:02 (eventos 4634/4647 ou novo 4624), e o EDR pode confirmar qual processo fez a conexão.

Na Parte 2

TCP em profundidade (flags, handshake, quem iniciou a conexão), UDP, ICMP, os protocolos mais importantes para investigação com portas e perguntas de análise, leitura de logs de firewall, proxy e VPN, e Wireshark e tcpdump com desafios em PCAP. Ao final, o fechamento completo do Módulo 1: resumo, checklist geral, perguntas de entrevista e laboratório integrado.